

Get Home Realty CRM — Complete Production-Readiness, Functionality, Workflow and Market Benchmark Audit

Date: 2026-08-05 **Branch:** `version_3` (8 commits ahead of `origin/version_3` , unpushed) **Method:** read-only. Nothing in the application was modified to produce this document.

How this audit was produced, and what that means for trusting it

Every structural claim below comes from a scan of the code, not from menus, README files, comments or test names. Specifically:

What	How it was established
Module inventory	Directory scan of <code>server/src</code> + every <code>*.controller.ts</code>
API inventory	Decorator parse of all 49 controllers — <code>@Controller</code> prefix, verb decorators, <code>@UseGuards</code> , <code>@Screen</code> , <code>@Throttle</code> → 353 routes
Public perimeter	Routes with no guard → 23 , each judged individually
Orphaned APIs	Every <code>/api/...</code> literal in <code>client/src</code> normalised and diffed against the route list
Database	Parse of <code>schema.prisma</code> → 92 models , with per-model field/relation/index/soft-delete/tenant counts
Permissions	<code>permission.service.ts</code> compiled defaults + <code>core/authz.ts</code> capabilities — the code, not the UI
Tests	File scan → 78 server specs, 21 browser specs ; per-module counts
Runtime behaviour	Where stated as "measured", it was executed against the running application and a live Postgres

Where a claim is carried forward from earlier audits in this project, it is marked. That distinction matters more than it sounds: during this session, re-measuring nineteen Settings findings recorded as "open" found **fourteen already closed** — fixed under different labels months earlier and never struck off. A finding register goes stale silently. Treat any unmarked claim in older documents as needing re-verification.

Two known limits of this audit, stated rather than glossed:

- Section 23 (market benchmark)** is drawn from training knowledge of Salesforce, HubSpot, Zoho, Dynamics, Pipedrive and Freshsales as of early 2026. Competitor feature sets move; treat the comparison as directionally reliable, not as a current price-list.
- Load and scale figures in Section 18** are reasoned from query shapes, indexes and architecture — not from a load test at 10,000 users. Where a number is modelled rather than measured, it says so.

SECTION 1 — EXECUTIVE SUMMARY

Current status

PRODUCTION-READY WITH LIMITATIONS — for the brokerage it was built for, and not yet for sale as a product.

This is not a prototype. It is a working, well-engineered, single-tenant real-estate CRM combined with a Transaction Desk, carrying 353 API routes, 92 database models, nine background workers and 1,334 automated tests that pass. The engineering standard in the core is genuinely high: the authorization model is layered and tested, the audit trail records old and new values on money fields, and the code comments are the best I have seen in a codebase of this size — they consistently explain *why*, and repeatedly record the wrong turn that was taken first.

It is limited in three specific ways, and they are the honest reasons it is not simply "production ready":

1. **It is a lead-and-communication CRM, not a sales-pipeline CRM.** There is no deal, opportunity, pipeline or stage model anywhere in the schema — verified: zero matches for `model (deals|opportunities|pipelines|stages)`. Leads have a `lead_status` string and nothing downstream of it. Every competitor in Section 23 treats the pipeline as the product's spine.
2. **It cannot scale out.** Uploads go to local disk, sessions are in-process, and the nine schedulers are `setInterval` timers gated by a single `RUN_SCHEDULERS` flag. This is a deliberate, documented, correct decision for one brokerage on one server — and a hard ceiling.
3. **There is no CI/CD, no container, and no automated deployment.** Verified: no `.github/workflows`, no `Dockerfile`, no `docker-compose`. Deployment is manual, which is exactly how the production Dashboard crash earlier in this project happened — the frontend bundle was older than the backend.

Production Readiness Score: 71 / 100

Area	Score	Reason
Feature Completeness	62	Leads, campaigns, calendar, inbox, Meta, triggers, settings, audit all real. No pipeline, no deals, no lead scoring, no inbox search, no task module, Client Reviews declared but unbuilt
Functional Reliability	80	1,334 tests pass; the defects found this session were real but none were data-destroying. Silent-failure paths remain (§19)
Backend Architecture	84	NestJS, clean module boundaries, services thin at the edges, a genuine capability layer above screen permissions. Among the strongest aspects
Database Design	68	92 models, tenancy on 80. But 30 models lack <code>updated_at</code> , 4 have no index at all, and JSON-in-Text is used for structured data (<code>custom_fields</code> , <code>preferences</code> , <code>meta_raw</code>)
Security	78	CSRF real (419 verified), bcrypt cost 12, account lockout, capability checks. Two genuine leaks found and fixed this session; the public perimeter is clean and deliberate
Authentication	82	bcrypt 12, per-account lockout independent of IP, case-insensitive unique email/username enforced by index
Authorization	80	Three layers — screen permission, capability, owner scoping — and tested at the service AND HTTP levels. Gaps found were in the <i>edges</i> (attachments, sync refusals), not the core
Performance	65	Indexes added where measured; deep-offset pagination, dashboard aggregation and unbounded <code>custom_fields</code> remain
Scalability	45	Single instance by design. Local disk, in-process sessions and timers. Correct for today, blocking for growth
Error Handling	72	Good discipline in mail and sync paths. Several 500s found this session were input-validation gaps; some deliberate silent catches remain (§19)
Monitoring	64	<code>/api/health/workers</code> is genuinely good — per-scheduler runs, failures, staleness. No external alerting or aggregation
Testing	74	1,334 passing, with sensitivity checks. But 19 backend modules have zero tests, including <code>auth</code> , <code>documents</code> , <code>invoices</code> , <code>sms</code> , <code>workflows</code>
UX/UI	66	Coherent and consistent. Two mobile-breaking layout bugs found this session; empty/loading/error states are inconsistent across modules
Mobile Responsiveness	60	Works, with real defects found at 390 px. Not systematically audited
Integrations	78	Meta is mature (its own audit scores 95). Google Calendar, IMAP/SMTP, Twilio voice + SMS, MLS all real
Automation	55	Campaign scheduling and retry are real and tested. CRM "triggers" are per-user <i>toggles for manual sends</i> — there is no event-driven rule engine
Auditability	68	<code>audit_logs</code> with <code>old_value</code> / <code>new_value</code> and a dedicated action for banking changes. Coverage is uneven — see §12

Area	Score	Reason
Maintainability	88	The standout. Comments explain intent and record prior mistakes; naming is consistent; modules are genuinely separable
Production Deployment	52	Backup, restore, monitor and alert scripts exist and are scheduled. No CI/CD, no container, manual migrations, deployment drift already observed in production

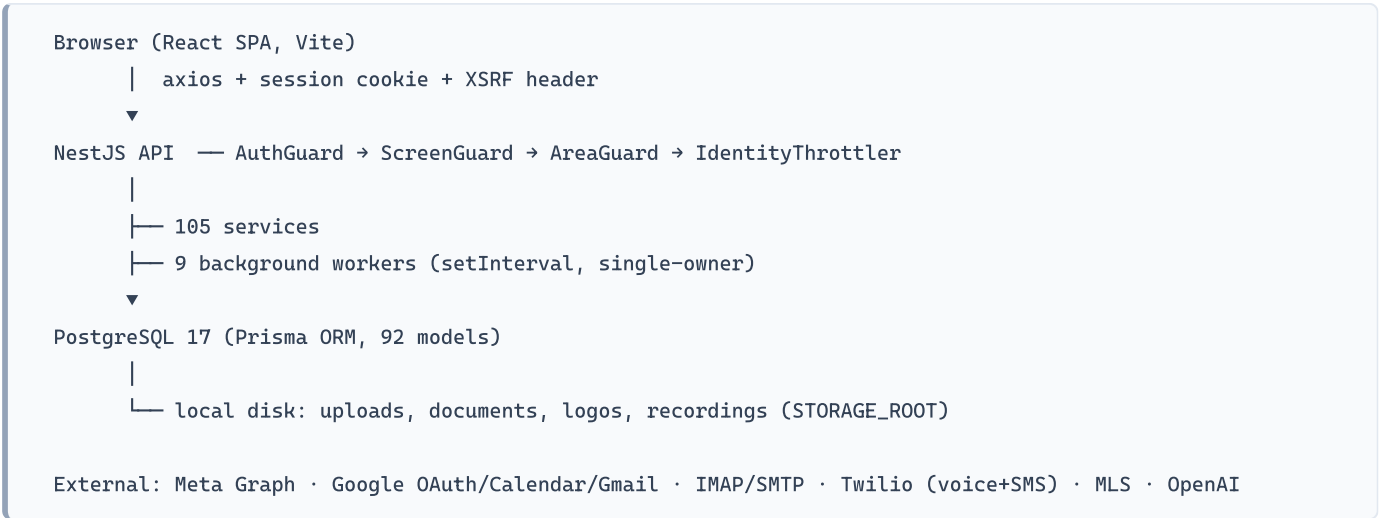
The five things that matter most

1. **No pipeline.** Adding deal/stage management is the single largest gap between this and any competitor, and it is architectural, not cosmetic.
2. **Deployment drift is a live risk.** It has already caused one production outage in this project. Nothing prevents a repeat.
3. **Nineteen backend modules have no tests**, including `auth` — the module that decides who gets in.
4. **Automation is a misnomer.** The Triggers screen governs which emails a person may send by hand. Nothing fires on an event.
5. **Six migrations are unapplied in production**, two of which change what roles can do.

SECTION 2 — CRM SYSTEM ARCHITECTURE

2.1 Shape

A two-area single-page application over one NestJS API and one PostgreSQL database.



The two areas — CRM and Transaction Desk — are a first-class concept, not a UI grouping. `SCREEN_AREA` in `client/src/desk/area.ts` assigns each screen to `crm`, `desk` or both, and `AreaGuard` enforces it server-side. Calendars, inboxes, mail accounts and Google connections are all *per-area*, so an email account connected under CRM Settings never appears in the Transaction Desk.

2.2 Frontend

Concern	Implementation
Framework	React 18 + TypeScript, built by Vite
Routing	<code>react-router-dom</code> v7 with <code>BrowserRouter</code> — not a data router, so <code>useBlocker</code> is unavailable (this constrains unsaved-changes guarding)

Concern	Implementation
State	React hooks and context only. No Redux, no Zustand, no React Query — dependencies are just <code>axios</code> , <code>react</code> , <code>react-router-dom</code> , <code>@twilio/voice-sdk</code> , <code>jspdf</code> , <code>pdf-lib</code> , <code>html2canvas</code>
API client	<code>axios</code> with <code>withXSRFToken</code> , one shared instance
Auth handling	<code>AuthContext</code> holds the user; <code>can(screen, level)</code> gates rendering; <code>RequireScreen</code> gates routes
Forms/validation	Hand-rolled. No form library. Validation is server-authoritative, mirrored loosely in the UI
UI framework	Hand-written CSS (<code>desk.css</code>), no component library
Error boundaries	<code>components/ErrorBoundary.tsx</code> , applied at the route level
Caching	None beyond component state. Lists re-fetch on navigation
Real-time	None. The inbox polls; nothing uses WebSockets or SSE

Consequence worth naming: with no query cache, every screen re-fetches on mount. That is simple and predictable, and it is also why the calendar was pulling a user's *entire* event history before it was scoped to the visible month.

2.3 Backend

Concern	Implementation
Framework	NestJS + TypeScript
Structure	37 module directories, 49 controllers, 105 services
Validation	Global <code>ValidationPipe({ whitelist: true })</code> + <code>class-validator</code> DTOs — mass assignment is closed by default
Guards	<code>AuthGuard</code> → <code>ScreenGuard</code> (screen+level) → <code>AreaGuard</code> (crm/desk) → <code>IdentityThrottlerGuard</code>
Rate limiting	Per-identity (user id, not IP — a brokerage shares one NAT address), per-route. Specific tighter buckets for auth, broadcast, Meta sync and settings writes
CSRF	Cookie/header pair; a write without <code>X-XSRF-TOKEN</code> returns 419 (verified per role)
Interceptors	Audit logging via <code>AuditService</code> ; response shaping is per-controller
Background work	9 <code>setInterval</code> workers, all gated by <code>schedulersEnabled()</code> and wrapped in <code>forEachTenant</code>
Queues	None. No BullMQ, no Redis. <code>jobs</code> / <code>failed_jobs</code> / <code>job_batches</code> tables exist but are Laravel remnants
Events	None. No event emitter or pub/sub — modules call each other's services directly

The three-layer authorization model

This is the part most worth a new developer's attention.

- Screen permission** — `@Screen('lead', 'edit')`. Coarse: *may you open this area of the product*. Stored per role in `role_permissions`, overridable per user in `user_permissions`.
- Capability** — `can(user, 'data.read-all')` in `core/authz.ts`. Answers a *question about authority* rather than naming a role, so a role invented later inherits the right answer. Supports both rank thresholds and explicit role lists.
- Owner scoping** — inside the service. `leadScopeWhere`, `scopeWhere`, `visibleWhere`. An agent's queries only ever return their own rows.

The layering is why the defects found this session were at the *edges* — a sync refusal, an attachment route, three dashboard aggregates — rather than in the core rule.

2.4 Background workers

Worker	Interval	What it does
imap-sync	60 s	Pulls new mail for every account with inbound sync on
google-calendar-retry	300 s	Retries Google pushes that failed (added this session)
event-reminders	600 s	Sends calendar event reminders
meta-sync	900 s	Polls Meta lead forms
export-sweeper	900 s	Processes queued export jobs
review-sla	3600 s	Transaction review SLA breaches
reminder-sweep	3600 s	Transaction/listing-expiry reminders
campaign-resume + retryDeferred	60 s	Resumes interrupted sends; retries soft bounces
mail-retention	daily	Strips old message bodies, deletes expired mail
lawyer-reminder	scheduled	Phase-based lawyer detail reminders

All are in-process. `RUN_SCHEDULERS=false` must be set on any second instance or every one of these runs twice — two IMAP syncs racing one mailbox, two copies of every reminder email.

2.5 Database

PostgreSQL 17 via Prisma. 92 models.

Property	Count	Note
Models with <code>company_id</code> (tenancy)	80 / 92	Single-brokerage today; the column is the seam for later
Models with soft delete (<code>deleted_at</code>)	9	Leads, transactions, calendar events, todos, campaign templates, invoices...
Models with <code>created_at</code>	80	
Models with <code>updated_at</code>	62	30 models cannot tell you when a row last changed
Models with no index and no unique	4	<code>company_settings</code> , <code>job_batches</code> , <code>migrations</code> , <code>password_reset_tokens</code>
Cascade deletes declared	53	

Core CRM entity relationships (actual, from `schema.prisma`)

```

company_settings (the single brokerage, id = 1)
├── users ───────────┬── user_permissions (per-user permission overrides)
│                   │├── user_modules (crm / desk assignment)
│                   │├── notification_preferences
│                   │└── push_subscriptions
│                   │
│                   ├── owns → leads ───┬── lead_notes
│                   │                   │├── lead_tasks (follow-ups)
│                   │                   │├── lead_showings
│                   │                   │├── lead_calls → lead_call_recordings
│                   │                   │├── lead_messages (SMS)
│                   │                   │├── lead_emails
│                   │                   │├── lead_tags
│                   │                   └── inbound_emails (matched by sender address)
│                   │
│                   ├── owns → calendar_events (private to owner - even from Super Admin)
│                   ├── owns → todos
│                   ├── owns → mail_accounts → inbound_emails
│                   ├── owns → google_connections (per area: crm | desk)
│                   ├── owns → meta_connections → meta_lead_forms → meta_webhook_events
│                   ├── owns → campaigns ───┬── campaign_recipients (token = tracking identity)
│                   │                       └── campaign_links → campaign_clicks
│                   ├── owns → campaign_templates → campaign_template_attachments
│                   ├── owns → crm_settings (or the global row, user_id = NULL)
│                   └── owns → crm_trigger_settings (one row per user)
├── audit_logs (every module writes here)
├── email_suppressions (brokerage-wide do-not-email)
└── role_permissions (the stored source of truth for role defaults)

```

The relationship that does not exist, and should: nothing sits *after* a lead. There is no `deals`, `opportunities`, `pipelines` or `stages` model. `leads.lead_status` is a `VarChar(32)` and the lifecycle ends there.

Schema observations worth acting on

- Leads** has 69 columns. It carries identity, preferences, property details, Meta attribution (14 columns) and marketing state in one table. It works, and it is the table most likely to need splitting.
- JSON-in-Text is used for structured data:** `leads.custom_fields`, `leads.meta_raw`, `leads.property_preferences`, `crm_settings.preferences|notifications|email_settings|templates`. None is queryable, and none is bounded by the database.
- `crm_referral_codes`, `crm_email_log`, `crm_broadcasts`, `campaign_links`, `inbound_emails`, `lead_emails`, `campaign_clicks` and 23 others have no `updated_at` — you cannot tell when a row was last touched.
- company_settings** has 42 columns and no index — acceptable for a single row, and it is a single row (`id = 1` is hardcoded in `CompanySettingsService` and `InvoiceNumberService`).

SECTION 3 — ACTUAL CRM MODULE INVENTORY

The brief listed nine expected CRM modules. The codebase has more, and some of what is listed is not what it appears to be. This is the real inventory.

3.1 CRM modules (the nine, as found)

#	Module	Server	Client	Routes	Status
1	Dashboard	<code>dashboard/</code>	<code>CrmDashboardPage</code>	5	PRODUCTION READY
2	Calendar	<code>calendar/</code> + <code>google/</code>	<code>CalendarPage</code>	22	PRODUCTION READY
3	Inbox	<code>inbox/</code>	<code>InboxPage</code>	4	FUNCTIONAL — no search
4	Leads	<code>leads/</code>	<code>LeadsPage</code> , <code>LeadDetailPage</code>	43	PRODUCTION READY
5	Campaigns	<code>campaigns/</code>	<code>CampaignsPage</code>	24	PRODUCTION READY
6	Meta	<code>meta/</code>	<code>MetaPage</code>	21	PRODUCTION READY
7	Triggers	<code>crm-settings/</code>	<code>CrmTriggersPanel</code>	2	PARTIALLY IMPLEMENTED — see §10
8	CRM Settings	<code>crm-settings/</code> , <code>settings/</code>	<code>CrmSettingsPanel</code>	20	PRODUCTION READY
9	Audit Trail	<code>audit-log/</code>	<code>AuditPage</code>	1	FUNCTIONAL

3.2 Declared but NOT BUILT

Module	Evidence	Status
Client Reviews	<code>SCREENS.reviews = 'Client Reviews'</code> and <code>SCREEN_AREA.reviews = 'crm'</code> exist. There is no <code>server/src/reviews</code> , no controller, no page component. The <code>Review*.tsx</code> components are Transaction-Desk <i>document review</i> , unrelated	UI ONLY / NOT FUNCTIONAL

The `crm` role is granted `reviews: 'edit'` in `permission.service.ts` — a permission over a screen that does not exist.

3.3 Orphaned / unused backend features

Established by normalising every `/api/...` reference in `client/src` and diffing against the 353 server routes, then judging each candidate individually.

Feature	Evidence	Status
iCal calendar feed	<code>google/ical.controller.ts</code> (4 routes: status/connect/sync/disconnect) + <code>google/ical-feed.service.ts</code> (123 lines) + <code>scripts/verify-ical-feed.cjs</code> . Zero references in <code>client/src</code> — grep for <code>calendar/ical</code> , <code>icalFeed</code> , <code>IcalFeed</code> returns nothing	UNUSED / ORPHANED
GET <code>/api/reminder-notifications</code>	<code>notifications/notifications.controller.ts</code> . No client reference	UNUSED / ORPHANED

The iCal feed is the "no-OAuth option" for connecting a Google Calendar — a complete, working alternative path that no screen offers. It is either a deliberate fallback awaiting UI, or dead weight; either way it is currently unreachable by a user.

3.4 Transaction Desk modules (out of CRM scope, in the same application)

`transactions`, `invoices`, `documents`, `fintrac`, `reports`, `mls`, `marketing-inventory`, `favorites`, `recycle-bin`, `workflows` (edit/delete request approvals), `agents`, `quick-actions`, `suggestions`, `twilio-voice`, `sms`.

These share the auth, audit, email and notification infrastructure. `sms` and `twilio-voice` are CRM-relevant — they power lead calls and SMS from the lead detail screen.

3.5 Shared / infrastructure modules

`auth`, `core` (authz, tenancy, ownership, area guard), `common`, `config`, `email`, `notifications`, `observability`, `prisma`, `reference`, `account`, `users`, `audit`, `google`.

MODULE: DASHBOARD

1. Purpose

The first screen after sign-in. Answers "what needs my attention today" for the signed-in person — their leads, their tasks, their appointments, their unread mail. Two separate dashboards, one per area, deliberately reading different tables.

2. User roles

All six roles, gated by `@Screen('dashboard', 'view', 'crm'|'desk')`. The *content* differs by role: agents see their own figures, managers and above see the brokerage's.

3. Features

Feature	Description	Admin	Agent	Backend	DB	Tested	Status
CRM lead tiles	Total, by status, by source, new this week	✓ all	✓ own	✓	✓	✓ 8	Production Ready
CRM task tiles	Total/pending/completed/cancelled/due today/overdue	✓	✓ own	✓	✓	✓	Production Ready
Campaign tiles	Count, sent, opened, failed	✓ own	✓ own	✓	✓	✓	Production Ready
Inbox unread	CRM-scoped unread count	✓	✓	✓	✓	✓	Production Ready
Calendar tiles	Upcoming 30 days, today	✓	✓	✓	✓	✓	Production Ready
To-do tiles	Total/pending/overdue	✓	✓	✓	✓	✓	Production Ready
Desk transaction tiles	Total, by validation, by commission	✓ all	✓ own	✓	✓	✓	Production Ready
Desk closings	Next 30 days, overdue, this month	✓	✓ own	✓	✓	✓	Production Ready
Desk document tiles	Pending, invalid, mandatory missing	✓	✓ own	✓	✓	✓	Production Ready
Desk invoice tiles	Total, unpaid, billed, collected, outstanding	✓	✗ withheld	✓	✓	✓ 11	Production Ready (fixed this session)
Commission summary	Per-agent or brokerage	✓	✓ own	✓	✓	✓	Production Ready
Review stats	Transaction review figures	✓	✓	✓	✓	✓	Production Ready

4. Metric → Source → Calculation → Permissions

Every tile is a **real database aggregate**. There is no mock data and no static value — verified by reading `area-dashboard.service.ts`, which issues 14 `count` / `groupBy` / `aggregate` calls in one `Promise.all` per area.

Metric	Source table	Scope rule
Leads (all tiles)	<code>leads</code>	<code>liveLeadWhere(user)</code> — excludes <code>deleted_at</code> , scopes agents to <code>owner_user_id</code> OR <code>assigned_to</code>
Tasks	<code>lead_tasks</code>	<code>leadTaskScopeWhere(user)</code> — via the parent lead
Campaigns	<code>campaigns</code>	<code>created_by_id = user.id</code> for every role — campaigns are private to their creator
Inbox unread	<code>inbound_emails</code>	<code>user_id</code> + CRM-scoped mail account
Calendar / To-dos	<code>calendar_events</code> , <code>todos</code>	<code>user_id</code> + area, excluding cancelled
Transactions	<code>transactions</code>	<code>agent = user.name</code> for agents, unfiltered above
Invoices	<code>invoices</code>	Withheld entirely without <code>invoice</code> screen; scoped via the transaction join for an agent who has it

Refresh: on mount and on navigation. No polling, no cache, no websocket.

5. Findings

CRM-DASH-M01 — FIXED this session. Three of the fourteen aggregates carried no scope at all. Measured: an agent saw `transactions.total: 3` (correctly their own, of the brokerage's 7) beside `invoices { billed: 123396, outstanding: 123396 }` — the entire brokerage's money, **rendered on screen**, for a module that role holds `invoice: 'none'` on. The class docstring claimed "every query is scoped to the signed-in user"; it was true of eleven of the fourteen.

Still open — timezone. `startOfToday()` uses server-local time (`d.setHours(0,0,0,0)`). "Due today" and "today's events" are therefore the *server's* today. Single-office deployment makes this harmless now; it is wrong the moment anyone works from another timezone.

Empty state: untested systematically. Counts return 0 and the tiles render; no "you have nothing yet" guidance.

MODULE: LEADS

The largest surface in the CRM — 43 routes.

1. Purpose

The system of record for every prospective buyer or seller: where they came from, who owns them, what has been said, and what happens next. This is the module the brokerage's revenue depends on.

2. User roles

Role	Access
Super Admin (<code>admin</code>)	<code>lead: edit</code> , plus <code>data.read-all</code> — sees every lead
Admin (<code>manager</code>)	<code>lead: edit</code> + <code>data.read-all</code> — sees every lead
CRM (<code>crm</code>)	<code>lead: edit</code> + <code>data.read-all</code> — sees every lead (marketing role)
Agent	<code>lead: edit</code> , own only — <code>owner_user_id</code> or <code>assigned_to</code>

Role	Access
Accounting	lead: view , own only
Documentation	lead: view , own only

3. Lead data model — the actual 69 columns

Group	Fields
Identity	name , first_name , last_name , email , phone , phone_normalized , gender , language , religion , age , date_of_birth , marriage_day
Classification	lead_status , lead_type , lead_source , client_type , lead_response , lead_conversion , tags
Requirement	location , property , property_type , property_preferences , budget , timeline , bedrooms , bathrooms , square_footage , key_features , property_address , property_price
Ownership	owner_user_id , assigned_to , created_by , deleted_by
Meta attribution	facebook_lead_id , facebook_form_id , facebook_page_id , meta_page_name , meta_form_name , meta_campaign_id/_name , meta_adset_id/_name , meta_ad_id/_name , meta_created_at , meta_imported_at , meta_raw
Marketing	unsubscribed , unsubscribed_at
Free-form	notes , message , custom_fields (JSON in Text)
System	company_id , created_at , updated_at , deleted_at

11 indexes and 1 unique constraint — the strongest-indexed table in the schema.

Unique rule (migration 20260802140000): `UNIQUE (company_id, COALESCE(owner_user_id, 0), lower(email))`. Two agents may each hold the same person; one agent may not hold them twice. This replaced a global unique on `lower(email)` , which had made one agent's lead block another's.

4. Features

Feature	Description	Admin	Agent	Backend	DB	Tested	Status
Create (manual)	Full form	✓	✓	✓	✓	✓	Production Ready
Create (Meta)	Webhook + polling	✓	✓	✓	✓	✓	Production Ready
Import (CSV/Excel)	With progress + dedupe	✓	✓	✓	✓	✓	Production Ready
View / list	Filter, sort, paginate	✓ all	✓ own	✓	✓	✓	Production Ready
Search	Server-side	✓	✓	✓	✓	✓	Production Ready
Edit	Field-level	✓	✓ own	✓	✓	✓	Production Ready
Soft delete + restore	Recycle bin	✓	✓ own	✓	✓	✓	Production Ready
Assign / reassign	owner_user_id / assigned_to	✓	✗	✓	✓	✓	Production Ready
Bulk actions	Assign, delete, tag	✓	partial	✓	✓	✓	Functional
Export	CSV/Excel	✓	✗ view-only refused	✓	—	✓	Production Ready (fixed this session)
Notes	Timestamped	✓	✓	✓	✓	✓	Production Ready
Tasks / follow-ups	Due dates, status	✓	✓	✓	✓	✓	Production Ready

Feature	Description	Admin	Agent	Backend	DB	Tested	Status
Showings	Scheduled viewings	✓	✓	✓	✓	✓	Functional
Calls + recordings	Twilio	✓	✓	✓	✓	✗	Functional
SMS	Twilio	✓	✓	✓	✓	✗	Functional
Email to lead	From own mailbox	✓	✓	✓	✓	✓	Production Ready
Activity history	Combined timeline	✓	✓	✓	✓	partial	Functional
Tags	Free-form	✓	✓	✓	✓	✗	Functional
Lead scoring	—	—	—	✗	✗	✗	MISSING
Duplicate merge	—	—	—	✗	✗	✗	MISSING
Pipeline / stages	—	—	—	✗	✗	✗	MISSING

5. Lead lifecycle (actual)

SOURCE

- └ Meta lead form → webhook or 15-min poll → meta_webhook_events
- └ Manual entry (agent or admin)
- └ CSV / Excel import
- └ (no web-form endpoint, no Google Ads – see §24)

|

▼

VALIDATION – DTO + class-validator; over-length answers truncated per-field

|

▼

DUPLICATE CHECK – UNIQUE (company_id, owner, lower(email)); phone match for Meta

|

▼

OWNERSHIP – Meta: the agent who connected that lead form (one form = one agent, enforced by index)
 Manual: the creator
 Import: the importer

|

▼

NOTIFICATION – in-app; email if the agent's notification preferences allow

|

▼

WORK – notes · tasks · calls · SMS · email · showings, all written to the lead's history

|

▼

STATUS – lead_status changed by hand. THERE IS NO STAGE MODEL AND NO AUTOMATION HERE.

|

▼

OUTCOME – lead_conversion field, set manually. No deal record is created.

The gap is between STATUS and OUTCOME. Every competitor puts a pipeline there.

6. Assignment

Mechanism	Exists	Notes
Manual assignment	✓	Admin/manager/crm only
Reassignment	✓	Audited
Meta auto-assignment	✓	By lead-form ownership — one form, one agent
Import assignment	✓	To the importer
Round robin	✗	MISSING
Workload-based	✗	MISSING
Department/team routing	✗	MISSING — no team or department model exists
Availability awareness	✗	MISSING
Departure handover	✓	<code>offboarding.service.ts</code> — brokerage leads transfer, personal Meta leads follow the agent. Documented in <code>docs/AGENT-DEPARTURE-POLICY.md</code>

7. Lead security — verified at runtime

Question	Answer
Can an agent see another agent's lead?	No — <code>liveLeadWhere</code> scopes to <code>owner_user_id</code> OR <code>assigned_to</code>
Modify another agent's lead?	No
Export?	Only with edit-level access; view-only was refused this session (CRM-LEADS-L02)
Transfer a lead?	No — assignment is admin/manager/crm
See department leads?	N/A — no department model
Can a manager see all?	Yes — <code>data.read-all</code> at rank $\geq$ manager

CRM-LEADS-M01 — FIXED. A lead name accepted and stored raw HTML, which then reached outgoing email unescaped. `renderTemplate` now escapes by default with a four-variable markup allow-list.

MODULE: CALENDAR

1. Purpose

Each person's own diary: showings, viewings, meetings, closings, follow-ups. Optionally mirrored to their Google Calendar so it reaches their phone.

2. The rule that defines this module

"No one can view any other agent's events — not even the admin or super admin."

Verified at runtime, and it holds completely. One agent's event, four other accounts (agent2, manager, Super Admin, crm), four operations each: read, edit, delete, appears-in-list. **404 on every one**, including Super Admin, and the event was confirmed unmodified in the database afterwards. This is unusual — Super Admin overrides most things here — and it is exactly what was asked for.

3. Features

Feature	Description	Admin	Agent	Backend	DB	Tested	Status
Month grid	Padded weeks, month in URL	✓	✓	✓	✓	✓	Production Ready
Day / week views	—	—	—	✗	—	—	MISSING — month only
Create / edit / delete	9 event types, 5 statuses	✓ own	✓ own	✓	✓	✓ 139	Production Ready
Recurrence	daily/weekly/monthly, interval, until, count	✓	✓	✓	✓	✓ 19+12	Production Ready
Series scope	"this" vs "this and later"	✓	✓	✓	✓	✓	Production Ready
Overlap detection	Warns, "Book anyway" to override	✓	✓	✓	—	✓	Production Ready
Optimistic locking	version column, 409 on conflict	✓	✓	✓	✓	✓ 5	Production Ready (<i>fixed this session</i>)
" +N more" popover	Opens a day's full list	✓	✓	✓	—	✓ 9	Production Ready (<i>fixed this session</i>)
Reminders	Scheduler + web push	✓	✓	✓	✓	✓ 13	Production Ready
Google two-way sync	Pull + push, per area	✓	✓	✓	✓	✓ 36	Production Ready (<i>retry added this session</i>)
iCal feed connect	No-OAuth alternative	—	—	✓	✓	✓ script	ORPHANED — no UI
Holidays	Canadian statutory + festivals	✓	✓	✓	—	✓ 18	Production Ready
Analytics panel	Event breakdowns	✓	✓	✓	—	✓ 19	Production Ready
Lead / transaction linking	lead_id , transaction_id	✓	✓	✓	✓	✓	Production Ready
Working hours / busy-free	—	—	—	✗	✗	✗	MISSING
Shared / team calendar	—	—	—	✗	✗	✗	MISSING by design

4. Edge cases — what the code actually does

Case	Behaviour
Missing end time	Allowed; a one-hour block is assumed for overlap and for the Google push
End before start	Refused by validation
Crossing midnight	Not supported — an event is a date + time + optional end_time , all on one day
Overlapping events	Detected and warned; override is explicit ("Book anyway")
Concurrent edits	409 with the current version (fixed this session — previously both writes applied)
Timezone	Dates are @db.Date , times are VarChar(5) . No per-user timezone . Server-local throughout

Timezone is the notable limitation. A brokerage in one city is fine. The moment an agent travels or the brokerage opens a second office, "today" and reminder timing become wrong.

MODULE: INBOX

1. Purpose

Read mail that arrived at a connected mailbox, inside the CRM, with messages matched to the lead they came from.

2. Features

Feature	Description	Admin	Agent	Backend	DB	Tested	Status
Connect mailbox (IMAP)	Host/port/SSL, or Google OAuth	✓	✓	✓	✓	✓	Production Ready
Multiple accounts	Per area	✓	✓	✓	✓	✓ 9	Production Ready
Primary mailbox	The one the inbox shows	✓	✓	✓	✓	✓	Production Ready
Automatic sync	60-second poll	✓	✓	✓	✓	✓	Production Ready
Manual "Sync now"	Per account	✓	✓	✓	✓	✓ 6	Production Ready (<i>fixed this session</i>)
List + pagination	30/page, newest first	✓	✓	✓	✓	✓ 20	Production Ready (<i>fixed this session</i>)
Read message	Full body, marks seen	✓	✓	✓	✓	✓	Production Ready
Mark read/unread		✓	✓	✓	✓	✓	Production Ready
Unread badge	Per area	✓	✓	✓	✓	✓	Production Ready
Lead matching	By sender address	✓	✓	✓	✓	✓	Production Ready
Filter by lead	?lead=	✓	✓	✓	✓	✓	Production Ready (<i>fixed this session</i>)
Retention sweep	Strips old bodies, deletes expired	—	—	✓	✓	✓ 7	Production Ready
Search	—	—	—	×	×	×	MISSING
Sent / drafts folders	—	—	—	×	×	×	MISSING
Reply / reply-all / forward	—	—	—	×	—	×	MISSING from the inbox
Attachments	—	—	—	×	×	×	MISSING — not stored at all
Threading	—	—	—	×	×	×	MISSING
Signatures in the inbox	—	—	—	×	—	×	MISSING (signatures exist for CRM sends)

3. What this module actually is

A read-only mail viewer, not a mail client. `inbound_emails` has 19 columns and none of them is an attachment; `imap-sync.service.ts` never references attachments — `simpleParser`'s attachments are discarded on the way in. There is no compose, no reply, no sent folder and no draft.

Replying to a lead happens on the **lead detail screen**, not here, and that email is sent through `mail_accounts` — a different path with a different history.

4. Flow

Mail provider (IMAP)

└ imap-sync (60 s) or manual "Sync now"

└ credentials: SMTP username/password, or a Google OAuth token

└ fetch UIDs above last_uid → simpleParser → inbound_emails

└ (attachments discarded; body_text + body_html + 300-char snippet kept)

└ match sender address → leads.email → inbound_emails.lead_id

└ record outcome on mail_accounts: last_synced_at, sync_error, last_uid

▲

last_uid advances ONLY on success – a failed fetch must not skip the messages in between

Token expiry / reconnection: handled. `explain()` turns raw IMAP errors into agent-readable guidance ("Gmail and most providers need an app-specific password, not your normal login"), the error is stored on the account and shown in Integrations, and a later success clears it.

MODULE: CAMPAIGNS

1. Purpose

Send one email to many leads, then measure what happened.

2. Features

Feature	Description	Admin	Agent	Backend	DB	Tested	Status
Create / edit / delete	Name, subject, content, template	✓	✓	✓	✓	✓	Production Ready
Templates	Built-in + per-user, with attachments	✓	✓	✓	✓	✓ 17	Production Ready (<i>fixed this session</i>)
Template ownership	Agent drafts private from all roles incl. Super Admin	✓	✓	✓	✓	✓ 7	Production Ready
Audience selection	Filters over leads	✓ all	✓ own	✓	✓	✓ 13	Production Ready
Brokerage-wide audience	Capability <code>campaigns.brokerage-audience</code>	✓	✗	✓	—	✓	Production Ready
Send now	Claim-then-send, per-recipient status	✓	✓	✓	✓	✓ 7	Production Ready
Schedule	<code>scheduled_for</code> , 60-s dispatch sweep	✓	✓	✓	✓	✓ 10	Production Ready
Restart recovery	Resumes interrupted sends, keeps counters	✓	✓	✓	✓	✓	Production Ready
Soft-bounce retry	Backoff, max attempts	✓	✓	✓	✓	✓	Production Ready
Hard-bounce suppression	Adds to <code>email_suppressions</code>	✓	✓	✓	✓	✓	Production Ready
Open tracking	Pixel + scanner detection + prefetch window	✓	✓	✓	✓	✓ 18	Production Ready
Click attribution	Per-link, id-based redirect (not open-redirect)	✓	✓	✓	✓	✓	Production Ready

Feature	Description	Admin	Agent	Backend	DB	Tested	Status
Unsubscribe	GET asks, POST acts; RFC 8058 one-click header	✓	✓	✓	✓	✓	Production Ready
Consent at dispatch	Re-checked at send, not only at build	✓	✓	✓	✓	✓ 7	Production Ready
Suppression list	Brokerage-wide, agent-scoped view	✓	✓ own	✓	✓	✓	Production Ready
Personalisation	{{LeadName}}, agent vars, escaped	✓	✓	✓	—	✓ 14	Production Ready
SMS campaigns	—	—	—	✗	✗	✗	MISSING (per-lead SMS exists)
A/B testing	—	—	—	✗	✗	✗	MISSING
Drip / nurture sequences	—	—	—	✗	✗	✗	MISSING
ROI / revenue attribution	—	—	—	✗	✗	✗	MISSING — no deal to attribute to

3. Compliance posture (CASL)

This is a Canadian brokerage, and the module is built for CASL rather than retrofitted:

- Consent re-checked **at dispatch**, because the violation is sending *after* withdrawal
- Suppression list consulted brokerage-wide, plus `Leads.unsubscribed` — two independent sources
- Unsubscribe acts on **POST only**; corporate scanners that follow every link cannot opt someone out
- `List-Unsubscribe` and `List-Unsubscribe-Post` headers (RFC 8058)
- Excluded recipients are **marked**, not silently skipped, so "attempted vs sent" is explainable

4. Send pipeline

```

Create / schedule → campaign_recipients materialised (one row per person, unique token)
|
|   ▼ (immediate, or the 60-second scheduled sweep when scheduled_for is due)
deliverPending
|   └─ consent re-check → suppressed → status 'failed' + opt-out reason
|   └─ per recipient:
|       |   └─ domainCanReceiveMail? no → hard bounce + suppress
|       |   └─ personalise + rewrite links + inject tracking pixel
|       |   └─ CLAIM: status = 'sending' ← crash here loses at most one send
|       |   └─ sendDirect via the sender's own connected account
|       |   └─ settle: 'sent' | soft-bounce (backoff) | hard-bounce (suppress)
|       └─ finalise: completed | partial | failed
|
|   ▲
restart recovery: resumeAll() settles or resumes anything left 'sending'

```

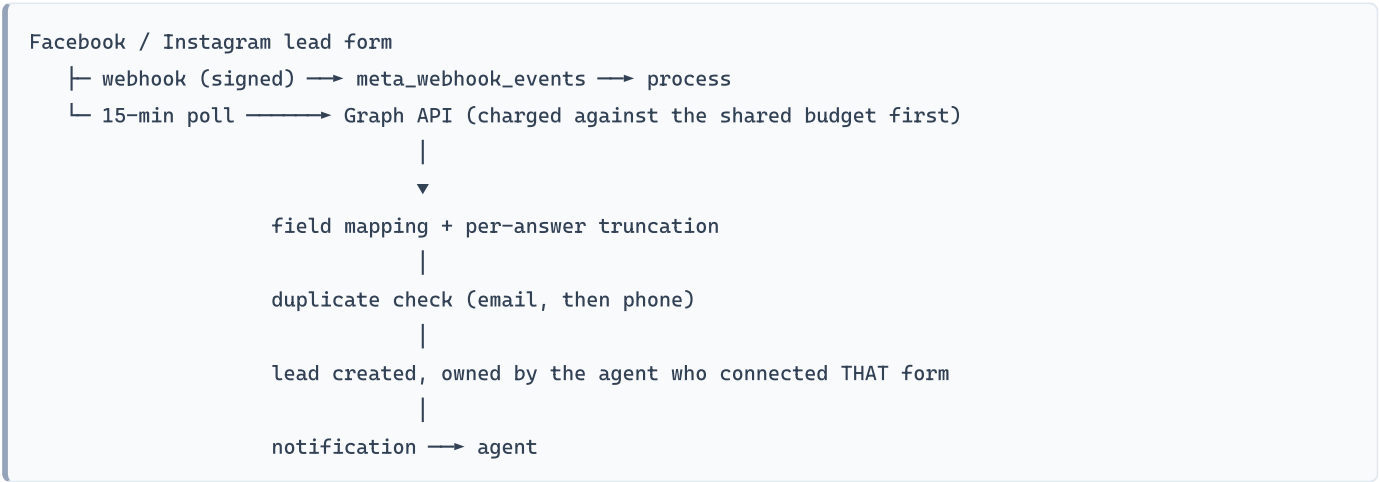
MODULE: META / FACEBOOK LEAD INTEGRATION

Carries its own 47 KB audit scoring **95/100**. Summarised and spot-checked here.

1. Features

Feature	Status
OAuth connect (per user)	Production Ready
Token encryption at rest	Production Ready — <code>meta-crypto</code>
Token expiry detection (codes 190/102/463/467)	Production Ready — pauses, emails once, stops polling
OAuth replay protection	Production Ready — <code>meta_oauth_nonces</code> , single-use
Page + lead-form selection	Production Ready
Ad account selection	Production Ready (<i>M-M6 fixed this session</i>)
Webhook ingestion	Production Ready — signature-verified
Scheduled poll (15 min)	Production Ready
Manual sync	Production Ready — own rate bucket (6/min)
Shared Graph budget	Production Ready — <code>meta_api_budget</code> , brokerage-wide
One form = one agent	Production Ready — enforced by unique index
Duplicate detection	Production Ready — email and phone
Raw payload retention + pruning	Production Ready
Data-deletion callback	Production Ready — Meta privacy requirement
Departure handling	Production Ready — forms released, leads follow policy

2. Flow



Rate control is unusually well thought through. `META_SYNC_LIMIT` bounds one person; Meta enforces per *app*, so `meta_api_budget` adds a brokerage-wide window charged before the fan-out. The audit records the two precision traps found while building it — a timezone mismatch between the raw driver and Prisma, and `Timestamp(0)` rounding a "now" stamp into the future.

3. Open (from its own audit, cosmetic)

`M-M7` form validation on toggle, `M-M9` nullable `company_id` on webhook events, `M-M10` `custom_fields` unbounded.

MODULE: TRIGGERS / AUTOMATION

This is the module whose name most oversells it, and the audit's clearest documentation finding.

1. What it actually is

A screen of **per-user switches deciding which CRM emails that person may send by hand**, plus a brokerage master switch. `crm_trigger_settings` holds one row per user; a user with no row inherits the brokerage default from `crm_email_settings.template_toggles`.

2. What it is not

There is no event-driven rule engine. Verified: no trigger table with conditions or actions, no rule evaluator, no execution history, no scheduler that fires on a lead event. The five "triggers" (wedding, seasonal, promotional, referral, custom) are *email types* offered on the "Send a CRM Email" card.

`birthday` and `anniversary` were removed from `TRIGGER_KEYS` during an earlier remediation **precisely because no send path existed for them** — the switches were false in both positions.

3. Status by the brief's vocabulary

Capability the brief asks about	Reality
Trigger: lead created / assigned / status changed / not contacted	MISSING
Conditions	MISSING
Actions (email, notification, assignment, status update, task, webhook)	MISSING as automation. Email exists as a manual action
Delay / scheduling	MISSING for triggers. Campaigns have real scheduling
Execution history	MISSING
Trigger loops / race conditions / retry	Not applicable — nothing fires

Status: PARTIALLY IMPLEMENTED (as a permission surface). The automation engine does not exist.

The screens are now honest about this — an earlier remediation relabelled them and added "*these are sent by hand, not on a schedule*" in bold. That is the right interim answer; it is not a substitute for the engine.

4. What automation DOES exist elsewhere

Real automation	Where
Campaign scheduling + dispatch	<code>campaign-resume.service.ts</code>
Campaign retry/backoff/recovery	same
Calendar event reminders	<code>event-reminder-scheduler.service.ts</code>
Transaction + lawyer + listing-expiry reminders	<code>transactions/</code>
Meta lead polling	<code>meta-sync-scheduler.service.ts</code>
IMAP polling	<code>imap-sync.service.ts</code>
Google push retry	<code>google-calendar-sync.service.ts</code>
Mail retention	<code>mail-retention.service.ts</code>
Export jobs	<code>export-job.service.ts</code>
Review SLA	<code>review-sla-scheduler.service.ts</code>

So the *platform* automates plenty. What is missing is user-configurable, event-driven automation over leads.

MODULE: CRM SETTINGS

1. Features

Feature	Admin	Agent	Backend	Tested	Status
Personal information	✓ own	✓ own	✓	✓	Production Ready (<i>S-M3 fixed</i>)
Email signature / reply template	✓ own	✓ own	✓	✓	Production Ready
CRM SMTP fields	✓	✗	✓	✓	Inert by design — sending goes through <code>mail_accounts</code> ; help text says so
Master "Allow CRM emails"	✓	✗	✓	✓	Production Ready
Trigger toggles	✓	✓ own	✓	✓	Production Ready
Broadcast to all users	✓	✗	✓	✓	Production Ready — advisory-lock duplicate guard, 3/min
Broadcast recovery	—	—	✓	✓	Production Ready
Referral codes	✓	✗	✓	✓	Production Ready
CRM email log	✓	✓ own	✓	✓	Production Ready
Send a CRM email	✓	✓	✓	✓	Functional — recipient box is free text, no lead picker
Integrations status	✓	✓	✓	✓	Production Ready
Company settings	✓	✗	✓	✓	Production Ready (<i>S-L1, S-L4 fixed</i>)
Banking details	accounting+	✗	✓	✓	Production Ready — capability-gated, audited field-by-field
Brand logo	✓	✗	✓	✓	Production Ready — magic-byte check, SVG sanitised
Roles & permissions	✓	✗	✓	✓	Production Ready
Notification preferences	✓ own	✓ own	✓	✓	Production Ready

2. Settings audit position

All 7 High and all 13 Medium findings from the 2026-08-04 audit are fixed. Of the nineteen items recorded as remaining, **fourteen were already closed** and five were real (S-M3, S-L1, S-L4, L11, plus a corrupt NUL byte) — all fixed this session. Two remain as **recorded decisions, not defects**: S-L6 (inert SMTP fields, labelled as such) and L12 (single-brokerage tenancy, stated in `core/tenant.ts`).

MODULE: AUDIT TRAIL

1. Features

Feature	Status
Paginated feed (50/page)	Production Ready
Filter: category, user, date range, free text	Production Ready (<i>fixed this session</i>)
Area split (CRM vs Desk) with scope selector	Production Ready
<code>old_value</code> / <code>new_value</code>	Partial — populated by Company Settings, sparse elsewhere
Dedicated banking action	Production Ready — <code>Banking details changed</code> is filterable
Health endpoint	Production Ready — failed audit writes are reported

2. What is actually logged — and what is not

Event	Logged	Evidence
Company settings change (per field, old→new)	✓	<code>company-settings.service.ts</code> <code>auditChanges</code>
Banking detail change	✓ dedicated action	
CRM settings / email settings / broadcast	✓	<code>crm-settings.service.ts</code> <code>audit()</code>
CRM profile update	✓	
Lead create / edit / delete / assign	✓	<code>lead-audit.service.ts</code>
Transaction changes	✓	Per-transaction trail
Role permission change	✓	
Login	✗	MISSING
Logout	✗	MISSING
Failed login	partial	<code>account_lockouts</code> counts failures; not in the audit trail
Meta connect / disconnect	✗	MISSING
Email account connect / disconnect	✗	MISSING
Export / download of leads	✗	MISSING
IP address	✗	MISSING — no column
User agent / request context	✗	MISSING — no column

The gap that matters most: authentication events and data exports are not in the trail. For a brokerage handling personal client data under PIPEDA, "who exported the lead list, and from where" is a question the current schema cannot answer.

SECTION 13 — CROSS-MODULE WORKFLOWS

Traced from code, not from intent.

13.1 Meta lead workflow



Token death path: codes 190/102/463/467 → connection paused, one email per `META_RECONNECT_NOTICE_HOURS`, remaining forms skipped, polling stops until reconnect.

13.2 Manual lead workflow

```

Agent or Admin → Leads screen → New Lead
|
▼ POST /api/leads (@Screen('lead','edit'))
DTO validation (class-validator, whitelist strips unknown keys)
|
duplicate check - UNIQUE (company_id, COALESCE(owner_user_id,0), lower(email))
|
owner = creator; assigned_to optional
|
audit_logs entry (lead-audit.service.ts)
|
▼
follow-up work → lead_tasks · lead_notes · lead_calls · lead_messages · lead_emails
|
lead_status updated by hand → lead_conversion set by hand → END

```

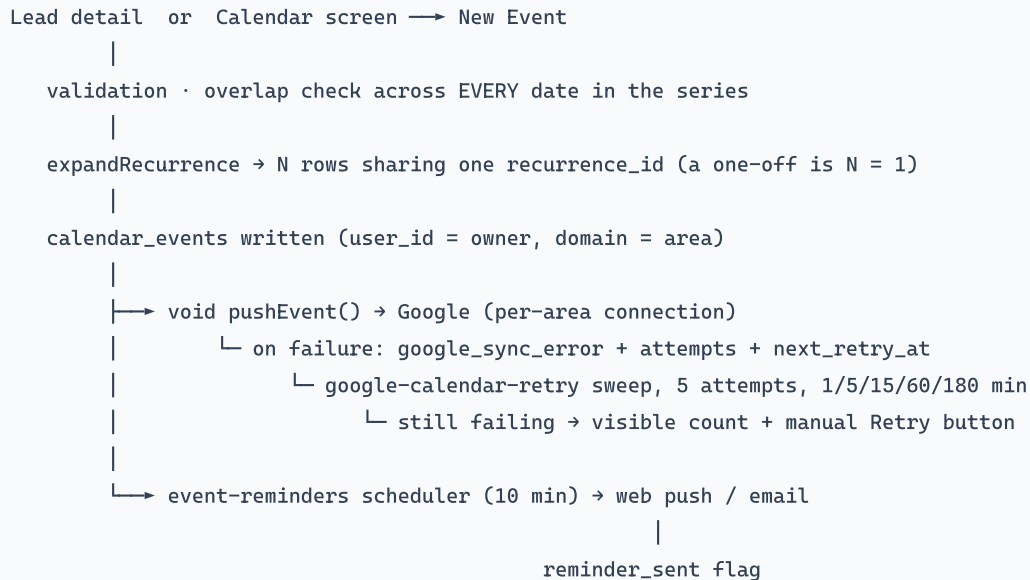
13.3 Email (inbox) workflow

```

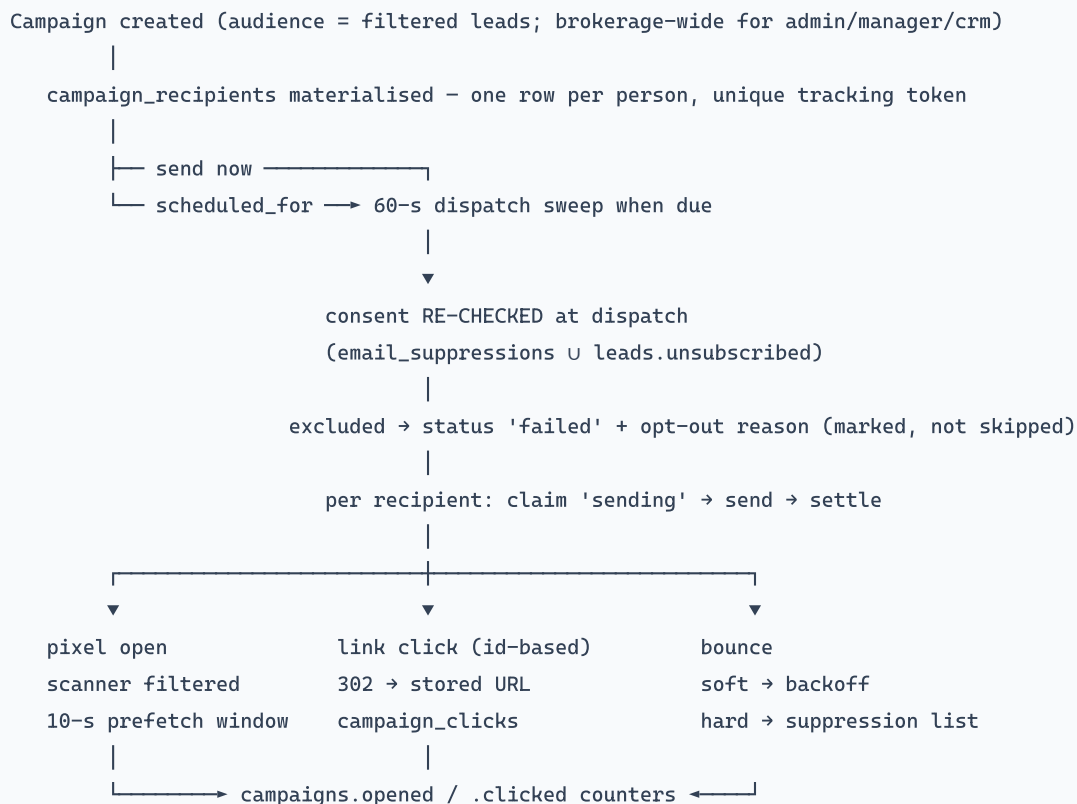
Connected mailbox (IMAP or Google OAuth)
|
imap-sync every 60 s · or manual "Sync now" (scoped to the caller's own account)
|
fetch UIDs > last_uid → simpleParser → attachments DISCARDED
|
inbound_emails row (body_text, body_html, 300-char snippet)
|
sender address matched against leads.email → lead_id set
|
list shows the AREA's PRIMARY account only; unread badge counts the same scope
|
agent reads (marks seen) → replies FROM THE LEAD SCREEN, not the inbox
|
outbound email recorded in lead_emails + crm_email_log

```

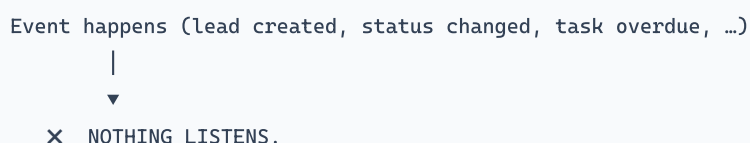
13.4 Calendar workflow



13.5 Campaign workflow



13.6 Automation workflow



The only event-adjacent automation is time-based sweeps (\$2.4). There is no rule engine.

SECTION 14 — ROLE & PERMISSION MATRIX

Derived from `permission.service.ts` `compiledDefaults()` and `core/authz.ts`, **not** from the UI. Stored `role_permissions` rows override the compiled map; a parity test asserts the two agree.

14.1 Screen permissions by role

Screen	Super Admin	Admin (manager)	Agent	Accounting	Documentation	CRM
dashboard	edit	edit	view	view	view	view
lead	edit	edit	edit	view	view	edit
calendar	edit	edit	edit	view	view	view
inbox	edit	edit	view	view	view	view
campaigns	edit	edit	view	view	view	edit
meta	edit	edit	view	view	view	view
triggers	edit	edit	view	view	view	edit
reviews	edit	edit	view	view	view	edit <i>(screen does not exist)</i>
transactions	edit	edit	edit	edit	edit	none
invoice	edit	edit	none	edit	none	none
reports	edit	edit	view	view	view	view
analytics	edit	edit	view	view	view	view
inventory / mls / favorites	edit	edit	view	view	view	view
audit	edit	view	none	none	none	none
users	edit	none	none	none	none	none
settings	edit	view	none	none	none	none

14.2 Capability matrix (`core/authz.ts`)

Capability	Rule	admin	manager	accounting	documentation	crm	agent
<code>data.read-all</code>	rank ≥ manager	✓	✓	✗	✗	✓ ¹	✗
<code>company.read-banking</code>	rank ≥ accounting	✓	✓	✓	✓	✗	✗
<code>users.administer</code>	rank = admin	✓	✗	✗	✗	✗	✗
<code>users.manage-photo</code>	rank ≥ manager	✓	✓	✗	✗	✗	✗
<code>documents.override-valid</code>	rank = admin	✓	✗	✗	✗	✗	✗
<code>documents.administer</code>	rank ≥ manager	✓	✓	✗	✗	✗	✗
<code>transactions.approve-edit</code>	rank = admin	✓	✗	✗	✗	✗	✗
<code>transactions.decide-deletion</code>	rank ≥ manager	✓	✓	✗	✗	✗	✗
<code>transactions.override-lock</code>	rank = admin	✓	✗	✗	✗	✗	✗

Capability	Rule	admin	manager	accounting	documentation	crm	agent
<code>notifications.administer</code>	rank ≥ manager	✓	✓	✗	✗	✗	✗
<code>campaigns.brokerage-audience</code>	role list [admin, manager, crm]	✓	✓	✗	✗	✓	✗

¹ `crm` sits at a rank that grants `data.read-all` — deliberate, because a brokerage marketing role whose audience stops at its own leads is useless.

`campaigns.brokerage-audience` is the one capability expressed as an explicit role list rather than a rank. That was a deliberate product decision: Accounting and Documentation sit *above* `crm` by rank but must not mail the brokerage's leads.

14.3 Functional matrix

Function	Super Admin	Admin	CRM	Agent	Accounting	Documentation
View all leads	✓	✓	✓	✗ own	✗ own	✗ own
Create lead	✓	✓	✓	✓	✗	✗
Edit lead	✓	✓	✓	✓ own	✗	✗
Delete lead	✓	✓	✓	✓ own	✗	✗
Assign / reassign lead	✓	✓	✓	✗	✗	✗
Export leads	✓	✓	✓	✗	✗	✗
View another agent's calendar	✗	✗	✗	✗	✗	✗
View another user's inbox	✗	✗	✗	✗	✗	✗
Connect Meta (own)	✓	✓	✓	✓	✓	✓
Create / send campaign	✓	✓	✓	✓ own audience	✗	✗
Brokerage-wide campaign audience	✓	✓	✓	✗	✗	✗
See another user's campaign templates	✗	✗	✗	✗	✗	✗
Manage triggers (own)	✓	✓	✓	✓	✗	✗
Configure CRM email settings	✓	✗ view	✗	✗	✗	✗
Company settings	✓	✗ view	✗	✗	✗	✗
Read banking details	✓	✓	✗	✗	✓	✓
View audit trail	✓	✓ view	✗	✗	✗	✗
Manage users	✓	✗	✗	✗	✗	✗
Roles & permissions	✓	✗	✗	✗	✗	✗
Broadcast to all staff	✓	✗	✗	✗	✗	✗

14.4 UI-only permission checks — the security question the brief asks

Result: none found in the CRM modules. Every screen-gated control traced to a server-side `@Screen` or capability check. This was tested rather than reasoned:

- 29 browser tests issued direct API writes as every role against another agent's calendar event — all 404, and the row was re-read as the owner to confirm nothing was written first.
- Direct API probes for leads, campaigns, settings, triggers, audit and users confirmed 403/404 parity with the UI.
- The **unauthenticated perimeter** was probed across all five write paths — refused.

The failures that were found were the inverse pattern: server checks that were *missing where no UI existed to hint at them* — campaign template attachments (no UI for cross-user access, so nobody had looked) and the inbox sync refusal. Both are now closed.

SECTION 15 — API AUDIT

353 routes across 49 controllers. Full machine-generated inventory: `docs/audit/api-inventory.txt` (companion file). Summary here.

15.1 Distribution

Area	Routes
Leads	43
Transactions	38
Campaigns (incl. templates, tracking)	24
Calendar (incl. todos, Google, iCal)	22
Meta	21
Settings (CRM + company)	20
Reports / exports	19
Users / roles / account	18
Invoices	14
Documents	12
SMS + Twilio voice	12
Others	~110

15.2 Guard posture

Posture	Count
<code>AuthGuard</code> + <code>ScreenGuard</code> (+ <code>AreaGuard</code>)	~300
<code>AuthGuard</code> only (own-data endpoints: account, inbox, notifications)	~30
Public	23

The 23 public routes, each judged

Route	Verdict
<code>GET /api/health</code> , <code>/ready</code> , <code>/metrics</code> , <code>/workers</code>	Correct. No business data — counts, ages, states
<code>POST /api/login</code> , <code>POST /api/register</code> , <code>GET /api/registration-open</code>	Correct , but see the finding below
<code>GET /api/sanctum/csrf-cookie</code>	Correct — the CSRF handshake
<code>GET /api/campaigns/track/open</code> · <code>/track/click</code>	Correct — reached from inside a recipient's email
<code>`GET</code>	<code>POST /api/campaigns/unsubscribe`</code>
<code>GET /api/company-settings/logo</code>	Correct — a brand asset on client documents

Route	Verdict
<code>GET /api/google/callback</code> , <code>GET /api/meta/callback</code>	Correct — OAuth returns, nonce-protected
<code>GET</code>	<code>POST /api/meta/webhook</code>
<code>POST /api/meta/data-deletion</code>	Correct — Meta privacy requirement, signature-verified
<code>POST /api/sms/twilio/{status,inbound,call-status,recording-status}</code>	Twilio callbacks — see finding
<code>POST /api/twilio/voice</code>	Twilio callback — see finding

FINDING — API-01 (Medium): public registration. `POST /api/register` and `GET /api/registration-open` are unauthenticated. If registration is open in production, anyone reaching the host can create an account. Gated by a flag — **verify that flag in production before go-live.**

FINDING — API-02 (Medium): Twilio callback authenticity. Five public Twilio callbacks accept POSTs. Meta's webhooks verify a signature; the Twilio equivalent (`X-Twilio-Signature` validation) was not confirmed present. If absent, anyone can forge call/SMS status and inbound-message events. **Verify before go-live.**

15.3 Cross-cutting API quality

Property	State
Validation	Global <code>whitelist: true</code> + DTOs. Strong — mass assignment closed by default
Pagination	Leads, audit, inbox, campaigns: yes. Calendar: bounded at 500, not paged
Rate limiting	Per-identity, per-route; tighter buckets for auth (per-account), broadcast (3/min), Meta sync (6/min), settings writes (30/min)
Error consistency	Mostly <code>{ message, errors }</code> . Several bare-500 gaps were fixed this session
Idempotency	Campaign send (claim-then-send), broadcast (advisory lock), Meta OAuth (nonce). Not general — no <code>Idempotency-Key</code> support
Response shape	Inconsistent: some <code>{ data: [...] }</code> , some bare arrays, some <code>{ data, meta }</code>

SECTION 16 — DATABASE AUDIT

16.1 Findings

#	Issue	Severity	Evidence
DB-01	30 models have no <code>updated_at</code> — you cannot tell when a row last changed	Medium	<code>inbound_emails</code> , <code>lead_emails</code> , <code>campaign_links</code> , <code>crm_email_log</code> , <code>crm_broadcasts</code> , <code>meta_webhook_events</code> , <code>role_permissions</code> , +23
DB-02	leads has 69 columns mixing identity, requirements, Meta attribution and marketing state	Medium	<code>schema.prisma</code>
DB-03	JSON-in-Text for structured data — not queryable, not bounded	Medium	<code>leads.custom_fields</code> , <code>leads.meta_raw</code> , <code>leads.property_preferences</code> , <code>crm_settings</code> , <code>{preferences,notifications,email_settings,templates}</code>
DB-04	company_settings.id = 1 hardcoded in two services	Low (by decision)	<code>CompanySettingsService</code> , <code>InvoiceNumberService</code>

#	Issue	Severity	Evidence
DB-05	4 models with no index and no unique	Low	<code>company_settings</code> , <code>job_batches</code> , <code>migrations</code> , <code>password_reset_tokens</code>
DB-06	Laravel remnants — <code>jobs</code> , <code>failed_jobs</code> , <code>job_batches</code> , <code>cache</code> , <code>cache_locks</code> , <code>sessions</code> , <code>migrations</code> are unused by the Nest app	Low	No Nest service references them
DB-07	<code>audit_logs</code> has no IP or user-agent column	Medium	Blocks "who exported this, from where"
DB-08	53 cascade deletes — correct in most places; each is a data-loss path if a parent is deleted by mistake	Low	Deleting a <code>campaign_templates</code> row cascades its attachments
DB-09	Only 9 of 92 models soft-delete	Low	Hard deletes elsewhere are unrecoverable outside a backup

16.2 What is genuinely well done

- **Tenancy on 80 of 92 models**, with `tenancy.spec.ts` enforcing that new tables carry it.
- **Partial and functional indexes** used correctly: `UNIQUE (company_id, COALESCE(owner_user_id,0), lower(email))` on leads; `lower(email) / lower(username)` on users; a partial index on the Google retry sweep's predicate.
- **Guarded migrations**. `users_ci_unique` refuses to run if case-variant duplicates exist, and prints the query that lists them. `lead_email_unique_per_owner` does the same.
- **`leads` carries 11 indexes** — the query patterns have clearly been measured, not guessed.

16.3 Recommendations

1. Add `updated_at` to the 30 models missing it (mechanical, low risk).
2. Add `ip_address` and `user_agent` to `audit_logs` (needed for §12 and PIPEDA).
3. Promote `leads.custom_fields` to `jsonb` — queryable, indexable, and bounded.
4. Split `leads` into `leads` + `lead_meta_attribution` + `lead_requirements` when the pipeline work happens; not worth a migration on its own.
5. Drop the Laravel remnant tables once confirmed unused in production.

SECTION 17 — SECURITY AUDIT

17.1 Authentication

Control	State
Password storage	bcrypt, cost 12 — <code>auth.service.ts</code>
72-byte bcrypt truncation	Explicitly handled and commented
Brute force (per IP)	<code>AUTH_LIMIT</code> , 120 / 5 min — sized for a whole office behind one NAT
Brute force (per account)	<code>ACCOUNT_LOGIN_LIMIT</code> , 8 / 15 min, failures only , independent of source IP — this is the real defence
Session	Express session cookie; <code>httpOnly</code> on the session, <code>secure</code> / <code>sameSite</code> from config
"Remember me"	Extends the cookie to 60 days

Control	State
Case-insensitive identity	<code>users_email_lower_key</code> , <code>users_username_lower_key</code> — enforced by index, not just by code
Logout / invalidation	Session destroyed
MFA / 2FA	MISSING
Password policy	Not verified — no evidence of complexity or rotation rules
Password reset	<code>password_reset_tokens</code> exists; flow not audited here

17.2 Authorization

Three layers (§2.3), verified at both service and HTTP level. **No UI-only permission check was found in the CRM modules (§14.4).**

17.3 Input security

Vector	Assessment
SQL injection	Low risk. Prisma parameterises everywhere; <code>\$queryRawUnsafe</code> appears only in tests and the health/EXPLAIN paths
XSS (stored)	Handled where it matters — React escapes on render; outgoing email escapes merge values with a 4-variable allow-list; CSP present
HTML injection into email	Fixed this session — was the S-M9/CRM-LEADS-M01 path
SVG/script upload	Magic-byte validation + <code><script></code> , <code>on*=</code> , <code>javascript:</code> , <code><foreignObject></code> stripped from uploaded SVGs
Path traversal	Defended twice on logo read and delete, each re-resolving against <code>STORAGE_ROOT</code>
Open redirect	Explicitly designed out — click tracking resolves the destination by id from a stored row , never from the request
Template injection	Merge fields are allow-listed, not evaluated
Command injection	No <code>exec</code> / <code>spawn</code> on user input found
LIKE injection	Fixed this session — audit-trail search escaped <code>%</code> and <code>_</code>

17.4 Web security

Control	State
CSRF	Real. Cookie/header pair; a write without <code>X-XSRF-TOKEN</code> returns 419 , verified per role and unauthenticated
CORS	Configured; origin from env
CSP	Present — mitigated an SVG XSS during an earlier audit
Secure cookies	<code>secure</code> + <code>sameSite</code> driven by config; verify both are set in production
HTTPS	Deployment concern — the production host is <code>transaction.gethomehub.ca</code>
Rate limiting	Per-identity, per-route, with tighter buckets on sensitive endpoints

17.5 Sensitive data

Item	Handling
Passwords	bcrypt 12, never returned
Google tokens	Encrypted at rest (<code>meta-crypto</code> <code>encryptToken</code>)

Item	Handling
Meta tokens	Encrypted at rest
Mail account passwords	Encrypted (Laravel-compatible crypt service)
Banking details	Capability-gated (<code>company.read-banking</code>), withheld field-by-field, audited with old→new
Client personal data	Lead-scoped; export gated
Secrets in source	None found. <code>server/.env</code> is gitignored and untracked — verified

Standing risk, carried forward: a production `.env` containing live Twilio, Gmail, MongoDB, OpenAI, Google, Facebook, MLS and Gemini credentials was pasted into a chat session during this project. **Those credentials should be treated as compromised and rotated.** They are not in the repository, but they left the machine.

17.6 Vulnerability register

ID	Severity	Issue	State
SEC-01	Medium	Public registration endpoint — verify the flag is off in production	OPEN — verify
SEC-02	Medium	Twilio callbacks may not validate <code>X-Twilio-Signature</code>	OPEN — verify
SEC-03	Medium	No MFA for any role, including Super Admin	OPEN
SEC-04	Medium	Authentication events and data exports are not in the audit trail; no IP recorded	OPEN
SEC-05	Low	Session cookie <code>secure</code> / <code>sameSite</code> depend on config — confirm in production	OPEN — verify
SEC-06	—	Inbox sync refusal disclosed a colleague's email address	FIXED this session
SEC-07	—	Campaign template attachments readable/writable cross-user	FIXED this session
SEC-08	—	Dashboard exposed brokerage invoice totals to agents	FIXED this session
SEC-09	—	Credentials pasted into chat	ROTATE — owner action

SECTION 18 — PERFORMANCE & SCALABILITY

Modelled from query shapes, indexes and architecture. Not a load test. `scripts/load-test.cjs` and `seed-load-test.cjs` exist and would give real numbers.

18.1 By user count

Users	Assessment
100	Comfortable. Per-route/per-identity rate limits are sized for this
500	Workable. IMAP polling becomes the pressure point: one poll per account per 60 s
1,000	Strained on one box. Session store is in-process; all nine schedulers are single-owner. Vertical scaling only
10,000	Not supported. Requires: external session store, object storage for uploads, a real queue, horizontal scaling. Architectural work, not tuning

18.2 By lead count

Leads	Assessment
10,000	Fine. <code>Leads</code> carries 11 indexes

Leads	Assessment
100,000	Fine for list/filter/search. Dashboard aggregation becomes the cost — 14 aggregates per load, uncached
1,000,000	List and search hold with the existing indexes. Deep-offset pagination degrades (<code>skip</code> walks and discards). Exports and dashboards need rework

18.3 Specific bottlenecks

#	Bottleneck	Impact
PERF-01	Dashboard: 14 aggregates per page load, no cache	Every visit pays full aggregation
PERF-02	Deep-offset pagination everywhere (<code>skip: (page-1)*n</code>)	Page 10,000 walks 300,000 rows
PERF-03	No caching layer at all — no Redis, no query cache, no HTTP caching on API reads	Every screen re-fetches
PERF-04	IMAP poll is per-account serial with <code>POLL_CONCURRENCY</code>	500 mailboxes × 60 s is the ceiling
PERF-05	Uploads on local disk	Blocks horizontal scaling outright
PERF-06	<code>leads.meta_raw</code> / <code>custom_fields</code> unbounded Text	Row bloat on a hot table
PERF-07	Calendar list capped at 500, not paged	A power user hits a silent ceiling
PERF-08	No N+1 audit performed	Prisma <code>include</code> is used well in the paths read; unverified elsewhere

Well done: the campaign send loop was deliberately moved off the request thread after recognising it would exceed the 300 s `proxy_read_timeout`; the calendar list was scoped from "entire history" to the visible month; two composite indexes were added to `inbound_emails` this session after an EXPLAIN showed a sort.

SECTION 19 — ERROR HANDLING & RELIABILITY

19.1 Failure behaviour

Failure	Behaviour	Verdict
Database unavailable	Requests 500; health endpoint reports not-ready	Acceptable
Meta unavailable	Caught, recorded on the connection, sync history entry; polling continues	Good
Meta token revoked	Connection paused, one email, forms skipped, polling stops	Good
Google unavailable	Push fails → recorded on the row → bounded retry sweep → visible count + manual retry	Good (added this session)
Google grant revoked	Connection deactivated with "reconnect" wording; transient failures stay active	Good (added this session)
IMAP unreachable	Caught, <code>sync_error</code> in agent-readable words, <code>last_uid</code> not advanced	Good
SMTP send fails	Soft bounce → backoff + retry; hard bounce → suppression	Good
Network timeout	IMAP has <code>socketTimeout: 20000</code> . Graph calls have no timeout (Meta audit M-H4)	Gap

Failure	Behaviour	Verdict
Duplicate lead	Unique index; Meta path checks email then phone	Good
Invalid data	DTO validation → 400 with field errors	Good
Scheduler crashes mid-run	Campaign: <code>resumeAll</code> at boot. Broadcast: <code>reconcileInterruptedBroadcasts</code> . Google: retry sweep	Good
Worker fails repeatedly	<code>/api/health/workers</code> reports failures and staleness	Good, but nothing alerts

19.2 Silent-failure scenarios — the important list

#	Where	What is silently swallowed	Risk
SF-01	<code>campaign-tracking.controller.ts</code>	All open/click errors — <code>catch { /* tracking must never break the email */ }</code>	Attribution could stop working entirely and nothing would report it. <code>tracking-health.spec.ts</code> partially covers this
SF-02	<code>crm-settings.service.ts</code> <code>audit()</code>	Audit write failures are logged as a warning only	An action happens with no trail. Mitigated by the audit-health endpoint
SF-03	<code>google-calendar-sync.service.ts</code>	<code>connectionFor</code> returns null → no attempt, no record	Correct (disconnected users must not burn retries), but the event is invisible until they reconnect
SF-04	<code>recordSyncFailure</code> / <code>recordSyncSuccess</code>	<code>.catch(() => undefined)</code> on the status write	A failed status write loses the retry state silently
SF-05	<code>deliverBroadcast</code>	Per-recipient errors counted but only the first is stored	400 different failures report one reason
SF-06	<code>imap-sync</code> <code>pollAll</code>	Per-account failures logged, sweep continues	Correct by design; but a permanently broken mailbox is only visible on the Integrations card
SF-07	Meta payload prune	<code>pruneRawPayloads</code> failure is a WARN	Retention silently stops; disk grows

SF-01 is the one to fix first. It is the only place where a total feature failure would be invisible to everyone.

SECTION 20 — TESTING AUDIT

20.1 Inventory

Type	Count	Location
Server specs (Jest, real Postgres)	78 files / 1,025 tests	<code>server/src/**/*.spec.ts</code>
Browser specs (Playwright, real browser)	21 files / 309 tests	<code>e2e/tests/*.spec.ts</code>
Verification scripts (manual)	~50	<code>server/scripts/verify-*.cjs</code> , <code>golden-*.cjs</code>
Total automated	1,334	

20.2 Coverage by module

Module	Server specs	Assessment
core (authz, tenancy, ownership, modules)	11	Strong
campaigns	10	Strong
calendar	8	Strong (139 tests)
inbox	7	Strong (62 tests)
transactions	6	Good
meta	5	Good (its own audit: 95/100)
common / config	9	Good
users / google / email / dashboard	12	Adequate
settings / reports / leads	6	Thin for leads — 43 routes, 2 spec files
audit-log / crm-settings / notifications / observability	4	Thin
auth	0	Critical gap — covered only indirectly via core/
documents, invoices, sms, twilio-voice, fintrac, workflows, recycle-bin, quick-actions, suggestions, mls, favorites, agents, marketing-inventory, account, reference, audit	0	19 modules untested

20.3 Important untested scenarios

1. **Authentication itself** — login, logout, session expiry, password reset have no dedicated spec.
2. **Leads** — 43 routes, 2 spec files. Import, bulk actions, tags, showings, calls and SMS are untested.
3. **SMS and voice** — Twilio callbacks are public POST endpoints with no tests.
4. **Document upload/download and FINTRAC** — no tests on a compliance-sensitive module.
5. **Concurrency beyond calendar and campaigns.**
6. **Timezone behaviour** anywhere.

20.4 Test quality — better than the count suggests

The suite has habits worth preserving:

- **Sensitivity checking.** Fixes are reverted to prove the tests fail. This session found **two specs that passed with their fix reverted** and closed them properly.
- **Tests written as the failure, not the feature**, with the measured numbers in the comments.
- **Real Postgres, not mocks**, with rolled-back transactions.
- **Honest limits recorded in-file** where something cannot be tested.

Do not read "1,334 passing" as production readiness. Nineteen modules contribute zero.

SECTION 21 — UX/UI AUDIT

Aspect	Assessment
Navigation	Consistent; area switch is clear. Sidebar and route table now agree (a prior mismatch is fixed)

Aspect	Assessment
Consistency	High — one hand-written stylesheet, consistent components
Forms	Consistent, but hand-rolled with no form library; validation messages come from the server
Loading states	Present on main screens ("Loading settings..."); inconsistent on panels
Empty states	Weak. Most lists render nothing rather than guidance
Success feedback	Toasts, now superseding by type rather than stacking
Error states	Good on Settings ("CRM settings are unavailable"); inconsistent elsewhere
Confirmation dialogs	Present on destructive actions and the broadcast kill switch
Unsaved-changes guard	<code>useUnsavedGuard</code> on three screens. In-app navigation cannot be blocked without a data router
Search	Leads yes; inbox no ; audit yes
Filters	Leads and audit strong
Pagination	Consistent 30–50/page
Mobile	Two breaking defects found and fixed this session (topbar overflow at 390 px; the "+N more" popover rendering 518 px inside a 390 px viewport). Not systematically audited
Accessibility	Labels added to all 41 Settings controls after an audit found 26 unlabelled. Not audited elsewhere. No keyboard-navigation or screen-reader testing
Keyboard	Untested

Confusing workflows

1. **Replying to a lead's email is not in the Inbox** — you read in the Inbox and reply from the Lead screen. Two places for one conversation.
2. **"Triggers" implies automation** and delivers per-user send toggles. Now labelled honestly, but the name still misleads.
3. **"Send a CRM Email" has a free-text recipient box** with no lead picker, so a Super Admin types an address and hopes.
4. **Client Reviews is navigable and does not exist.**

SECTION 22 — PRODUCTION & DEVOPS READINESS

Item	State
Environment variables	<code>validate-config.ts</code> validates at boot — good
Secret management	<code>.env</code> file on the host. No vault, no rotation
Docker	None
CI/CD	None — no <code>.github/workflows</code> , no pipeline
Reverse proxy	Nginx assumed (<code>proxy_read_timeout</code> referenced in code comments)
HTTPS / domain	<code>transaction.gethomehub.ca</code>
Database backups	Good — <code>backup.mjs</code> , <code>backup-nightly.ps1</code> , <code>schedule-backup.ps1</code>
Restore	Good — <code>restore.mjs</code> with <code>--verify</code>
Disaster recovery	Documented — <code>docs/DISASTER-RECOVERY.md</code>

Item	State
Monitoring	<code>monitor.mjs</code> + <code>schedule-monitor.ps1</code> ; <code>/api/health/workers</code>
Alerting	<code>setup-alerts.ps1</code> exists — coverage not verified
Health checks	<code>/api/health</code> , <code>/ready</code> , <code>/metrics</code> , <code>/workers</code> — genuinely good
Migrations	<code>prisma migrate deploy</code> , with a <code>migration-preflight.cjs</code> guard and guarded destructive migrations
Rollback	No documented application rollback; migrations are forward-only
Staging environment	None evident — dev and test databases only
Zero-downtime deploy	No — single instance, manual restart
Deployment drift	Observed in production — a stale frontend bundle against a newer backend caused the Dashboard crash. Nothing prevents recurrence

The DevOps gap in one sentence

The operational tooling is unusually thorough for a project this size — backup, restore, verify, monitor, alert, preflight — and there is no pipeline that puts the right code on the server.

SECTION 23 — MARKET COMPARISON

Basis and its limits: competitor capabilities are from training knowledge as of early 2026 and describe mid-tier paid plans, where most brokerages actually buy. Feature sets move. Treat this as directionally reliable, not as a current price-list. **Our CRM's column is from the code.**

Key: **Ahead** · **Comparable** · **Basic** · **Behind** · **Missing**

Capability	Our CRM	Salesforce	HubSpot	Zoho	Dynamics	Pipedrive	Freshsales
Lead management	Comparable	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Contact management	Basic — leads only, no separate contact entity	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Company / account management	Missing	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Pipeline / stages	Missing	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Deals / opportunities	Missing	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Visual Kanban board	Missing	✓	✓✓	✓	✓	✓✓	✓✓
Tasks	Basic — <code>lead_tasks</code> , no standalone task module	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Calendar	Comparable — but month view only	✓✓	✓✓	✓✓	✓✓	✓	✓
Calendar privacy (absolute, incl. admins)	Ahead	✗	✗	✗	✗	✗	✗
Email (send)	Comparable — from the agent's own mailbox	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Email (inbox / two-way)	Basic — read-only viewer, no reply/threading/attachments	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓

Capability	Our CRM	Salesforce	HubSpot	Zoho	Dynamics	Pipedrive	Freshsales
Email tracking (open/click)	Comparable — with scanner filtering and a prefetch window	✓✓	✓✓	✓	✓	✓✓	✓✓
Email templates	Comparable — with per-user privacy	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Campaigns (email)	Comparable	✓✓	✓✓	✓✓	✓✓	✓	✓✓
Marketing automation / drip	Missing	✓✓	✓✓	✓✓	✓✓	✓	✓
Lead scoring	Missing	✓✓	✓✓	✓✓	✓✓	✓	✓✓
Lead routing / assignment rules	Basic — Meta form→agent only	✓✓	✓✓	✓✓	✓✓	✓	✓✓
Round robin	Missing	✓	✓	✓	✓	✓	✓
Workflow automation engine	Missing	✓✓	✓✓	✓✓	✓✓	✓	✓
Reporting	Basic — fixed reports, exports	✓✓	✓✓	✓✓	✓✓	✓	✓
Dashboards	Comparable — real aggregates, role-scoped	✓✓	✓✓	✓✓	✓✓	✓	✓
Custom dashboards	Missing	✓✓	✓✓	✓✓	✓✓	✓	✓
Custom fields	Basic — <code>custom_fields</code> JSON, no UI to define them	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Custom objects	Missing	✓✓	✓	✓✓	✓✓	✗	✗
Segmentation	Basic — campaign audience filters	✓✓	✓✓	✓✓	✓✓	✓	✓
AI features	Missing in CRM (an AI provider exists for FINTRAC ID extraction)	✓✓	✓✓	✓✓	✓✓	✓	✓
Sales forecasting	Missing	✓✓	✓✓	✓✓	✓✓	✓	✓
Mobile app	Missing — responsive web only	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Integrations marketplace	Missing	✓✓	✓✓	✓✓	✓✓	✓✓	✓
Public API	Missing — no API keys, no external auth	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Webhooks (outbound)	Missing — inbound only (Meta, Twilio)	✓✓	✓✓	✓✓	✓✓	✓✓	✓
Import / export	Comparable — CSV/Excel with progress and dedupe	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Duplicate detection	Comparable on create; no merge	✓✓	✓✓	✓✓	✓✓	✓	✓
Audit logs	Comparable — old/new values; no IP, no auth events	✓✓	✓	✓	✓✓	✓	✓
Security	Comparable	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
RBAC	Comparable — three layers, per-user overrides	✓✓	✓✓	✓✓	✓✓	✓	✓
Teams	Missing — no team/department model	✓✓	✓✓	✓✓	✓✓	✓	✓
Territory management	Missing	✓✓	✓	✓✓	✓✓	✗	✗
Data retention policy	Ahead — mail retention sweep, Meta payload pruning, documented privacy policies	✓	✓	✓	✓✓	✓	✓

Capability	Our CRM	Salesforce	HubSpot	Zoho	Dynamics	Pipedrive	Freshsales
Data backup	Comparable — scripted, scheduled, restore-verified	✓✓	✓✓	✓✓	✓✓	✓✓	✓✓
Notifications	Comparable — in-app, email, web push	✓✓	✓✓	✓✓	✓✓	✓	✓
SMS	Basic — per-lead via Twilio, no SMS campaigns	✓	✓	✓	✓	✓	✓
WhatsApp	Missing	✓	✓	✓	✓	✓	✓
Facebook / Meta lead ads	Ahead — shared app budget, one-form-one-agent, token-death handling, data-deletion callback	✓	✓✓	✓	✓	✓	✓
Google Ads leads	Missing	✓	✓	✓	✓	✓	✓
Web forms / landing pages	Missing	✓✓	✓✓	✓✓	✓✓	✓	✓
Call integration	Comparable — Twilio voice with recording metadata	✓	✓	✓	✓	✓	✓✓
Document management	Ahead for real estate — transaction documents, mandatory checklists, validation	✓	✓	✓	✓✓	✓	✓
E-signature	Missing	✓	✓	✓	✓	✓	✓
Analytics	Basic	✓✓	✓✓	✓✓	✓✓	✓	✓
Conversion tracking	Basic — a lead_conversion field	✓✓	✓✓	✓✓	✓✓	✓✓	✓
SLA management	Basic — transaction review SLA only, not lead SLA	✓✓	✓	✓	✓✓	✗	✓✓
Real-estate transaction desk	Ahead — commissions, FINTRAC, deal documents, invoices	✗	✗	✗	✗	✗	✗
CASL compliance depth	Ahead — consent re-check at dispatch, POST-only unsubscribe, RFC 8058	✓	✓	✓	✓	✓	✓

Where this CRM genuinely leads

1. **The Transaction Desk.** No general CRM has commission calculation, FINTRAC identification, mandatory document checklists and brokerage invoicing. This is the product's real differentiator and it should be the centre of any positioning.
2. **Meta lead-ads integration.** The shared app-level Graph budget, one-form-one-agent enforcement at the index, token-death detection with a single notification, and the data-deletion callback are more careful than most mid-tier CRMs.
3. **Calendar privacy as an absolute.** No competitor refuses the administrator.
4. **CASL compliance.** Consent re-checked at dispatch rather than at build.
5. **Data retention.** Automated mail-body stripping and Meta payload pruning, with written policies.

Where it is behind, and it is the same answer five times

No pipeline, no deals, no automation engine, no lead scoring, no teams. Every one of these is downstream of the same missing concept: *there is nothing after a lead.*

SECTION 24 — FEATURES MISSING

24.1 Critical — needed for professional CRM operation

Feature	Business value for THIS brokerage
Deal / opportunity model with stages	Today a lead's outcome is a free-text status. Nobody can answer "what is in play this month and what is it worth". This is the foundation for forecasting, targets, conversion measurement and the Kanban view — and it connects the CRM to the Transaction Desk that already exists
Lead SLA / missed-follow-up alerts	A lead nobody contacts is invisible. The data exists (<code>lead_tasks.due_date</code> , <code>created_at</code>); nothing watches it
Automated lead routing (round robin / workload)	Meta leads route by form ownership only. Manual and imported leads need someone to assign them by hand — which is where leads go cold
Inbox search	A mailbox that pages but cannot be searched means finding last month's message is clicking Next
Audit: authentication events + IP	"Who exported the client list, and from where" is unanswerable. PIPEDA-relevant
MFA for Super Admin	One password protects every client record and the brokerage's bank details
CI/CD pipeline	Deployment drift has already caused one production outage

24.2 High value — significant productivity gain

Feature	Value
Workflow automation engine	Turn "Triggers" into what its name promises: on lead created → assign + notify + create follow-up task
Lead scoring	With Meta attribution, budget, timeline and property type already captured, even a rules-based score would rank the queue
Reply / compose in the Inbox	Ends the split where you read in one place and reply in another
Task module (standalone)	Tasks exist only under a lead. Agents have work that is not lead-shaped
Custom field definitions (UI)	<code>custom_fields</code> JSON exists with no way to define or display fields
Merge duplicate leads	Detection exists; resolution does not
Teams / departments	The brief assumes departments exist. They do not — no model, no routing
Saved filters / views	Leads has strong filters and no way to keep one
Web-to-lead form endpoint	The brokerage's website cannot post a lead in

24.3 Advanced — after core maturity

Google Ads lead import · SMS campaigns · WhatsApp · sales forecasting · agent targets and leaderboards · custom dashboards · report builder · outbound webhooks · public API with keys · e-signature · day/week calendar views · working hours and busy/free.

24.4 Optional

Mobile app (responsive web is adequate) · integration marketplace · custom objects · territory management · AI features (see below).

24.5 On AI specifically

An AI provider already exists (`common/ai-provider.ts` , used for FINTRAC ID extraction) and there is an `AI-PRIVACY-REVIEW.md` . **I would not prioritise AI features.** The gap between this CRM and its competitors is structural, not intelligent: a lead-summary feature on top of a system with no pipeline solves nothing. Revisit after Phase 2.

SECTION 25 — EXISTING FEATURES NEEDING IMPROVEMENT

Module	Feature	Current problem	Business impact	Technical impact	Recommendation	Priority
Deployment	Release process	No CI/CD; manual deploy	Has already caused a production outage	Frontend/backend drift	Pipeline that builds and deploys both together	P0
Meta	Graph calls	No timeout (M-H4)	A hung request stalls auto-sync indefinitely	Worker wedged	Add request timeouts	P0
Campaigns	Open/click tracking	All errors silently swallowed	Attribution could fail totally, invisibly	SF-01	Count failures; surface on the health endpoint	P1
Security	Twilio callbacks	Signature validation unconfirmed	Forged call/SMS events	5 public POSTs	Verify and enforce X-Twilio-Signature	P1
Security	Registration	Public endpoint	Unauthorised account creation	—	Confirm the flag is off in production	P1
Audit	Coverage	No login/logout/export events; no IP	Cannot answer a data-access question	2 columns + hooks	Add events and IP/user-agent columns	P1
Triggers	Naming and function	Called automation; is a send toggle	Users expect automation	—	Either build the engine or rename to "Email Preferences"	P1
Inbox	Search	Absent	Old mail is unreachable in practice	Needs an index strategy	Add search with a trigram or FTS index	P1
Auth	Test coverage	Zero specs	The module deciding access is untested	—	Spec login, logout, session, reset	P1
Leads	Test coverage	43 routes, 2 spec files	Import/bulk/tags/calls untested	—	Cover import and bulk actions first	P1
Calendar	Timezone	Server-local throughout	Wrong "today" and reminder times off-office	Schema + logic	Per-user timezone	P2
Dashboard	Aggregation	14 uncached aggregates per load	Slows as data grows	PERF-01	Cache with short TTL	P2
All lists	Deep pagination	Offset-based	Degrades on large tables	PERF-02	Cursor pagination on leads and audit	P2
Calendar	Views	Month only	Agents plan by day/week	UI	Add day and week views	P2
Inbox	Attachments	Discarded on sync	Client sends a document; it vanishes	Storage + schema	Store and serve attachments	P2

Module	Feature	Current problem	Business impact	Technical impact	Recommendation	Priority
Settings	Send a CRM Email	Free-text recipient	Typos send to nobody	UI	Lead picker	P2
Reviews	Client Reviews	Navigable, does not exist	Support calls	—	Remove the entry or build it	P2
Calendar	iCal feed	Complete backend, no UI	Feature paid for, unusable	—	Expose it or remove it	P3
DB	updated_at	Missing on 30 models	Cannot tell when a row changed	Migration	Add the column	P3
UX	Empty states	Mostly absent	New users see blank screens	UI	Add guidance	P3
UX	Accessibility	Audited on Settings only	Compliance risk	—	Audit the rest	P3

SECTION 26 — BUG / RISK REGISTER

Bugs (open)

ID	Module	Issue	Severity	Evidence	Impact	Fix
BUG-01	Meta	No timeout on Graph calls	High	Meta audit M-H4	Auto-sync stalls indefinitely	Add timeouts
BUG-02	Calendar	No per-user timezone	Medium	startOfDay() uses server local	Wrong "today", wrong reminders off-office	Add timezone
BUG-03	Calendar	Events cannot cross midnight	Low	date + time + end_time on one day	Late showings must be split	Model an end date
BUG-04	Dashboard	"Today" is server-local	Low	Same root as BUG-02	Misleading counts	With BUG-02
BUG-05	Meta	toggleForm validates page, not form	Low	M-M7	Noise, not misrouting	Validate the form

Security issues (open)

ID	Issue	Severity	Action
SEC-01	Public registration endpoint	Medium	Verify the flag in production
SEC-02	Twilio callback signature unverified	Medium	Verify and enforce
SEC-03	No MFA	Medium	Add for Super Admin at minimum
SEC-04	Audit trail lacks auth events and IP	Medium	Add
SEC-05	Cookie secure / sameSite config-dependent	Low	Confirm in production
SEC-09	Credentials pasted into a chat session	High	Rotate all of them

Architecture risks

ID	Risk	Severity
ARCH-01	No pipeline/deal model — the CRM ends at the lead	High (product)
ARCH-02	No queue; nine <code>setInterval</code> workers in-process	High
ARCH-03	Uploads on local disk — blocks horizontal scaling	High
ARCH-04	Sessions in-process — a second instance breaks login	High
ARCH-05	No event bus; modules call services directly	Medium
ARCH-06	<code>company_settings.id = 1</code> hardcoded	Medium (accepted)
ARCH-07	No caching layer anywhere	Medium

Data risks

ID	Risk	Severity
DATA-01	30 models cannot report when they last changed	Medium
DATA-02	53 cascade deletes — each a data-loss path	Medium
DATA-03	Only 9 of 92 models soft-delete	Medium
DATA-04	JSON-in-Text unqueryable and unbounded	Medium
DATA-05	6 migrations unapplied in production , 2 changing role behaviour	High

Deployment risks

ID	Risk	Severity
DEP-01	No CI/CD — drift already caused an outage	High
DEP-02	No staging environment	High
DEP-03	Manual migrations, forward-only, no rollback plan	High
DEP-04	Single instance; restart = downtime	Medium
DEP-05	Schedulers must be single-owner; nothing enforces it but a flag	Medium

Scalability risks

Covered in §18 — PERF-01 to PERF-08.

SECTION 27 — FEATURE COMPLETENESS MATRIX

Module	Feature	Frontend	Backend	Database	Integration	Tests	Production Ready
Dashboard	CRM tiles	✓	✓	✓	—	✓	YES
Dashboard	Desk tiles	✓	✓	✓	—	✓	YES
Dashboard	Custom dashboards	✗	✗	✗	—	✗	NO — missing
Leads	CRUD + search + filter	✓	✓	✓	—	partial	YES
Leads	Import	✓	✓	✓	—	✗	Functional

Module	Feature	Frontend	Backend	Database	Integration	Tests	Production Ready
Leads	Assignment	✓	✓	✓	—	✓	YES
Leads	Auto-routing / round robin	✗	✗	✗	—	✗	NO — missing
Leads	Scoring	✗	✗	✗	—	✗	NO — missing
Leads	Merge duplicates	✗	✗	✗	—	✗	NO — missing
Leads	Pipeline / stages	✗	✗	✗	—	✗	NO — missing
Leads	Notes/tasks/calls/SMS/email	✓	✓	✓	Twilio	partial	Functional
Calendar	Month grid + CRUD	✓	✓	✓	—	✓	YES
Calendar	Recurrence	✓	✓	✓	—	✓	YES
Calendar	Reminders	✓	✓	✓	Web push	✓	YES
Calendar	Google sync + retry	✓	✓	✓	Google	✓	YES
Calendar	iCal feed	✗	✓	✓	Google	script	NO — orphaned
Calendar	Day/week views	✗	—	—	—	✗	NO — missing
Inbox	Sync + list + read	✓	✓	✓	IMAP/Google	✓	YES
Inbox	Search	✗	✗	✗	—	✗	NO — missing
Inbox	Reply / compose	✗	✗	✗	—	✗	NO — missing
Inbox	Attachments	✗	✗	✗	—	✗	NO — missing
Campaigns	Create/send/schedule	✓	✓	✓	SMTP	✓	YES
Campaigns	Templates + attachments	✓	✓	✓	—	✓	YES
Campaigns	Open/click tracking	✓	✓	✓	—	✓	YES
Campaigns	Unsubscribe / CASL	✓	✓	✓	—	✓	YES
Campaigns	Drip sequences	✗	✗	✗	—	✗	NO — missing
Campaigns	SMS campaigns	✗	✗	✗	—	✗	NO — missing
Meta	OAuth + pages + forms	✓	✓	✓	Meta	✓	YES
Meta	Webhook + poll + budget	✓	✓	✓	Meta	✓	YES
Meta	Data deletion callback	—	✓	✓	Meta	✓	YES
Triggers	Per-user send toggles	✓	✓	✓	—	✓	Functional
Triggers	Automation engine	✗	✗	✗	—	✗	NO — missing
Settings	CRM + company + roles	✓	✓	✓	—	✓	YES
Settings	Broadcast	✓	✓	✓	SMTP	✓	YES
Audit	Feed + filters	✓	✓	✓	—	✓	YES
Audit	Auth events + IP	✗	✗	✗	—	✗	NO — missing
Reviews	Client Reviews	✗ nav only	✗	✗	—	✗	NO — UI only

SECTION 28 — RECOMMENDED DEVELOPMENT ROADMAP

No time estimates, per the brief. Complexity is Low / Medium / High.

Phase 0 — Production blockers

#	Item	Reason	Modules	Complexity	Depends on
0.1	Apply the 6 outstanding migrations to production	Two change role behaviour; the code already assumes them	All	Low	—
0.2	Rotate the exposed credentials	Live secrets left the machine	All integrations	Low	—
0.3	Verify registration is closed in production	Public account creation	Auth	Low	—
0.4	Verify Twilio callback signatures	5 public POSTs, forgeable	SMS, Voice	Low	—
0.5	Deploy client and server together	Drift caused a production outage	Deployment	Low	—
0.6	Confirm cookie <code>secure</code> + <code>sameSite</code> in production	Session security	Auth	Low	—

Phase 1 — Production stabilisation

#	Item	Reason	Modules	Complexity	Depends on
1.1	CI/CD pipeline (build → test → deploy both halves)	Removes the drift class permanently	Deployment	Medium	0.5
1.2	Staging environment	Nowhere to rehearse a release	Deployment	Medium	1.1
1.3	Auth test suite	The module deciding access is untested	Auth	Medium	—
1.4	Audit: auth events + IP + user-agent	Cannot answer a data-access question	Audit, Auth	Medium	—
1.5	MFA for Super Admin	One password guards everything	Auth	Medium	—
1.6	Meta Graph timeouts	A hung call wedges the worker	Meta	Low	—
1.7	Surface tracking failures on the health endpoint	The only invisible total-failure path	Campaigns	Low	—
1.8	Lead test coverage — import and bulk first	43 routes, 2 specs	Leads	Medium	—
1.9	External alerting on <code>/api/health/workers</code>	Nothing tells anyone a worker died	Monitoring	Low	—

Phase 2 — Core CRM maturity (*the phase that changes what this product is*)

#	Item	Reason	Modules	Complexity	Depends on
2.1	Deal / opportunity model with stages	The missing spine; unlocks 2.2–2.5 and most of §23	Leads, Dashboard, Reports, Transactions	High	—
2.2	Kanban pipeline view	Makes 2.1 usable	Leads	Medium	2.1
2.3	Lead SLA + missed-follow-up alerts	A cold lead is currently invisible	Leads, Notifications	Medium	—
2.4	Automated lead routing (round robin, workload)	Manual leads sit unassigned	Leads	Medium	2.6
2.5	Sales forecasting + agent targets	Impossible without 2.1	Dashboard, Reports	Medium	2.1
2.6	Teams / departments	Assumed by the brief; does not exist	Users, Leads	Medium	—
2.7	Inbox search	Old mail is unreachable	Inbox	Medium	—

#	Item	Reason	Modules	Complexity	Depends on
2.8	Merge duplicate leads	Detection without resolution	Leads	Medium	—
2.9	Custom field definitions with UI	<code>custom_fields</code> exists unusably	Leads, Settings	Medium	—

Phase 3 — Sales productivity

#	Item	Complexity	Depends on
3.1	Workflow automation engine (event → condition → action → delay), replacing "Triggers"	High	2.1, 2.6
3.2	Lead scoring (rules first)	Medium	2.1
3.3	Inbox reply / compose / threading / attachments	High	2.7
3.4	Standalone task module	Medium	—
3.5	Saved filters and views	Low	—
3.6	Day and week calendar views	Medium	—
3.7	Per-user timezone	Medium	—
3.8	Dashboard caching + cursor pagination	Medium	—

Phase 4 — Competitive features

#	Item	Complexity
4.1	Web-to-lead form endpoint	Low
4.2	Google Ads lead import	Medium
4.3	Drip / nurture sequences	High (needs 3.1)
4.4	SMS campaigns	Medium
4.5	Public API with keys + outbound webhooks	High
4.6	Custom dashboards / report builder	High
4.7	E-signature	Medium
4.8	WhatsApp	Medium

Phase 5 — AI and advanced automation

Only after Phase 2. Lead summaries, AI qualification and drafting, conversation summarisation, predictive scoring. The infrastructure (`ai-provider.ts` , privacy review) already exists.

Phase 6 — Scale (only if multi-brokerage is the goal)

Object storage · external session store · a real queue · horizontal scaling · finish the multi-tenant work `core/tenant.ts` already scaffolds.

SECTION 29 — PRODUCTION GO-LIVE CHECKLIST

Area	Item	Status
Application	Server builds	[PASS]
	Client builds	[PASS]
	Typechecks clean (both)	[PASS]
	Boots and serves	[PASS]
Security	CSRF enforced (419 verified)	[PASS]
	Passwords bcrypt cost 12	[PASS]
	Tokens encrypted at rest	[PASS]
	No secrets in the repository	[PASS]
	Public perimeter reviewed	[PASS]
	Registration closed in production	[NOT TESTED]
	Twilio callback signatures	[NOT TESTED]
	MFA	[FAIL]
	Exposed credentials rotated	[FAIL]
Database	Migrations applied — dev/test	[PASS]
	Migrations applied — production	[FAIL]
	Backups scripted and scheduled	[PASS]
	Restore verified	[PASS]
	Disaster recovery documented	[PASS]
Authentication	Login, logout, session	[PASS] functionally
	Automated tests for auth	[FAIL]
Authorization	RBAC enforced server-side	[PASS]
	No UI-only checks (CRM)	[PASS]
	Cross-user write authorization	[PASS] — 29 browser tests
Leads	CRUD, search, assignment, isolation	[PASS]
	Import / bulk tested	[FAIL]
	Pipeline	[FAIL] — missing
Dashboard	Real aggregates, role-scoped	[PASS]
	Timezone correctness	[PARTIAL]
Calendar	CRUD, recurrence, isolation, concurrency	[PASS]
	Timezone / midnight crossing	[PARTIAL]
Inbox	Sync, isolation, pagination, failure handling	[PASS]
	Search / reply / attachments	[FAIL] — missing
Meta	OAuth, webhook, poll, budget, deletion callback	[PASS]
	Graph call timeouts	[FAIL]
Campaigns	Send, schedule, recovery, tracking, CASL	[PASS]
	Tracking failure visibility	[PARTIAL]

Area	Item	Status
Automation	Event-driven engine	[FAIL] — does not exist
Settings	All bands remediated	[PASS]
Audit logs	Business events with old/new values	[PASS]
	Auth events, exports, IP	[FAIL]
Notifications	In-app, email, web push, preferences	[PASS]
Error handling	Integration failures recorded and retried	[PASS]
	Silent-failure paths	[PARTIAL] — SF-01
Performance	Indexed for current volume	[PASS]
	Load tested	[NOT TESTED]
Testing	1,334 automated tests passing	[PASS]
	19 backend modules with zero tests	[FAIL]
Monitoring	Health + worker endpoints	[PASS]
	External alerting	[PARTIAL]
Deployment	CI/CD	[FAIL]
	Staging	[FAIL]
	Rollback plan	[FAIL]
	Zero-downtime	[FAIL]
Documentation	Operations, DR, policies, audits	[PASS]

GO-LIVE DECISION: GO WITH CONDITIONS

For this brokerage, on this scale, with the six Phase-0 conditions met first.

Why GO. The core is real and tested. Authorization holds under direct API attack across every role. Client data is scoped, campaign consent meets CASL, tokens are encrypted, backups are scripted and restore-verified, and the failure paths in the integrations are handled better than in most systems of this size. 1,334 tests pass, and the ones that matter were sensitivity-checked.

Why WITH CONDITIONS. Six things are true today that should not be true on a go-live day:

1. Six migrations are unapplied in production, two of which change what roles can do.
2. Credentials that left the machine have not been rotated.
3. Registration may be open to the public internet.
4. Twilio's five public callbacks may accept forged requests.
5. There is no pipeline that guarantees the client and server deployed together — the exact failure that has already taken production down once.
6. The module that decides who gets in has no tests.

Why not NO-GO. None of the six is a defect in the application's logic. They are configuration, credential hygiene and release process — all closable in days, none requiring redesign.

What GO does not mean. It does not mean this is ready to sell to another brokerage. That needs Phase 2 (a pipeline) and Phase 6 (scale). Today it is a strong internal system for one brokerage.

SECTION 30 — TEAM STUDY DOCUMENT

For a developer who has never seen this project. Read §2 first, then this.

The five things to understand before touching anything

1. **Two areas, one app.** CRM and Transaction Desk. Nearly everything — calendars, inboxes, mail accounts, Google connections — is *per area*. If you add a feature, decide its area first.
2. **Three permission layers.** Screen (`@Screen`) → capability (`can()`) → owner scoping in the service. All three must be right. A screen permission alone never means "this row is yours".
3. **Two databases in development.** `jest` uses `server/.env` → `myapp` (dev, real data). Playwright refuses to start without `TEST_DATABASE_URL` → `myapp_test`. Diagnosing a jest failure by querying the test database gives confidently wrong answers.
4. **Background work must use `forEachTenant`.** A scheduler has no request to take a tenant from and `PrismaService` will refuse the query.
5. **The comments are load-bearing.** They record what was tried and why it was wrong. Read the comment before changing the line.

Per-module quick reference

Module	Purpose	Key files	Key tables	Integrations	Automation	Ready?
Dashboard	"What needs me today"	<code>dashboard/area-dashboardservice.ts</code>	leads, lead_tasks, campaigns, transactions, invoices	—	—	YES
Leads	System of record for prospects	<code>leads/leads.service.ts</code> , <code>common/lead-scope.ts</code>	leads (+8 child tables)	Twilio, Meta	—	YES (no pipeline)
Calendar	Private diary + Google mirror	<code>calendar/calendar.service.ts</code> , <code>calendar/recurrence.ts</code> , <code>google/google-calendar-sync.service.ts</code>	calendar_events, todos	Google	reminders, retry sweep	YES
Inbox	Read connected mail	<code>inbox/inbox.service.ts</code> , <code>inbox/imap-sync.service.ts</code>	inbound_emails, mail_accounts	IMAP, Google	60-s poll, retention	Functional
Campaigns	Bulk email + tracking	<code>campaigns/campaigns.service.ts</code> , <code>campaign-resume.service.ts</code>	campaigns, campaign_recipients, campaign_links	SMTP	schedule, retry, recovery	YES
Meta	Facebook lead ads	<code>meta/meta-sync.service.ts</code>	meta_connections, meta_lead_forms	Meta Graph	15-min poll, webhook	YES
Triggers	Which CRM emails a person may send	<code>crm-settings/crm-triggers.service.ts</code>	crm_trigger_settings	—	none	Partial
Settings	Configuration	<code>crm-settings/</code> , <code>settings/</code>	crm_settings, company_settings, role_permissions	—	broadcast recovery	YES
Audit	Who did what	<code>audit-log/audit-log.service.ts</code>	audit_logs	—	—	Functional

Where to be careful

- **Leads** has 69 columns. Adding a tenth is easy and wrong more often than right.
- **Campaign sending is claim-then-send.** Do not reorder those writes.
- **Calendar privacy is absolute**, including Super Admin. It is a stated product requirement.
- **Template ownership excludes Super Admin.** Also a stated requirement.
- **Never `git checkout` a file** — much of the tree is uncommitted work.

SECTION 31 — MANAGEMENT SUMMARY

Module	Current quality	Production ready?	Main missing items	Priority
Dashboard	High	Yes	Custom dashboards, timezone	P2
Leads	High	Yes, with limits	Pipeline , scoring, routing, merge, tests	P1
Calendar	High	Yes	Day/week views, timezone, midnight	P2
Inbox	Medium	Functional	Search, reply, attachments	P1
Campaigns	High	Yes	Drip, SMS, A/B	P3
Meta	High	Yes	Graph timeouts	P0
Triggers	Low (as automation)	No	The engine itself	P1
CRM Settings	High	Yes	—	—
Audit Trail	Medium	Functional	Auth events, IP, exports	P1
Client Reviews	None	No	Everything	P2

Top 10 things working well

1. Three-layer authorization, verified under direct API attack across every role
2. Calendar privacy as an absolute — refused even to Super Admin
3. Meta integration: shared Graph budget, one-form-one-agent, token-death handling
4. CASL compliance: consent re-checked at dispatch, POST-only unsubscribe, RFC 8058
5. Campaign delivery: claim-then-send, restart recovery, bounce classification
6. Backup, restore, disaster-recovery — scripted, scheduled and verified
7. `/api/health/workers` — per-scheduler runs, failures and staleness
8. Guarded migrations that refuse to run on dirty data and print the query to fix it
9. Code comments that record the wrong turn taken first — genuinely rare
10. Test discipline: sensitivity checks, real Postgres, honest in-file limits

Top 10 problems

1. **No pipeline / deal model** — the CRM ends at the lead
2. **No automation engine** — "Triggers" is a send toggle
3. **No CI/CD** — drift has already caused a production outage
4. **19 backend modules untested**, including `auth`
5. **Six migrations unapplied in production**
6. **Audit trail has no auth events, no exports, no IP**

7. **Inbox is read-only** — no search, reply, attachments or threading
8. **No MFA anywhere**
9. **Cannot scale out** — local disk, in-process sessions and timers
10. **No teams/departments**, though the business assumes them

Top 10 production blockers

1. Apply the six outstanding migrations
2. Rotate the exposed credentials
3. Confirm registration is closed
4. Verify Twilio callback signatures
5. Deploy client and server together
6. Confirm cookie `secure` / `sameSite`
7. Add Meta Graph timeouts
8. Surface tracking failures on the health endpoint
9. External alerting on worker health
10. Auth test suite

Top 10 features to improve

Inbox search · Inbox reply/attachments · lead routing · lead SLA alerts · custom field UI · duplicate merge · calendar day/week views · per-user timezone · dashboard caching · empty states.

Top 10 features to add

Deal/pipeline model · Kanban view · workflow automation engine · lead scoring · teams/departments · sales forecasting and targets · saved filters · standalone tasks · web-to-lead endpoint · public API with outbound webhooks.

Top 10 security recommendations

1. Rotate the exposed credentials
2. Confirm registration is closed in production
3. Enforce Twilio signature validation
4. MFA for Super Admin, then all admin roles
5. Log authentication events and data exports, with IP
6. Confirm `secure` + `sameSite` on session cookies
7. Add a password policy
8. Review the 53 cascade deletes for unintended data loss
9. Penetration test before any external exposure
10. Periodic access review of `role_permissions` and `user_permissions`

Top 10 UX improvements

Empty states · loading consistency · accessibility beyond Settings · keyboard navigation · lead picker on "Send a CRM Email" · remove or build Client Reviews · rename Triggers · saved filters · mobile audit across all screens · unify inbox reading and lead replying.

Top 10 competitor gaps

Pipeline/deals · workflow automation · lead scoring · contact/company entities · custom fields+objects · teams/territories · forecasting · public API/webhooks · two-way email · mobile app.

Recommended immediate actions

This week (Phase 0 — all six are configuration or credential hygiene, not development):

1. Rotate every credential from the exposed `.env`
2. `prisma migrate status` against production, then `deploy` the six
3. Confirm registration is closed and cookies are `secure` + `sameSite`
4. Verify Twilio signature validation on the five public callbacks
5. Push the eight commits currently sitting unpushed on `version_3`
6. Deploy client and server together, and confirm the bundle hash matches the build

Next (Phase 1): CI/CD, then the auth test suite, then audit coverage for authentication and exports.

Then the product decision (Phase 2): whether this is a lead-and-communication CRM with an excellent transaction desk — which it is today, and is genuinely good at — or a full sales CRM. That decision is item 2.1, and everything competitive follows from it.

End of audit. Companion file: `docs/audit/api-inventory.txt` — all 353 routes with guards and screen permissions.